

The Salesforce Threat Landscape

| Lessons and Risks for 2026

Table of contents

Executive summary

3

Salesforce Data as a High-Leverage Target

4

WithSecure Cloud Protection for Salesforce: Detection Telemetry and Threat Patterns

6

Malicious Detection Rates Observed in 2025

6

Geographic Distribution of Affected Organizations

7

Distribution of Malicious Detections by Content Type

8

Top Detections Observed in 2025

10

Adversary-in-the-Middle (AitM) Quishing Campaign

14

Publicly Reported Incidents

20

Identity-Based Access Abuse (Gehenna)

21

OAuth Device Flow Authorization Abuse (UNC6040)

22

Supply-Chain Compromise: Salesloft Drift Integration

24

Supply-Chain Compromise: Gainsight Integration

25

AitM Vishing Attacks Targeting SSO Identities

26

Salesforce as an Extortion Target in Leak-Site Campaigns

27

Emerging Salesforce Attack Surfaces: Agents, Automation, and Data Flows

28

Agents as Autonomous Actors

29

Automation as an Amplification Layer

30

Data as an Input to Automated Decision-Making

31

Proof-of-Concept: ForcedLeak

32

Salesforce Platform Security-Related Changes

34

Mitigation and Recommendations

35

Conclusion

39

Executive summary

In 2025, Salesforce environments became **direct targets of sophisticated, financially motivated cybercrime groups**. Historically, most Salesforce security incidents were associated with misconfigurations or vulnerabilities identified by security researchers. Over the past year, however, multiple incidents and extortion-driven campaigns demonstrated **deliberate targeting of Salesforce data as a high-leverage asset**.

Rather than exploiting platform vulnerabilities, attackers relied on social engineering, credential theft, OAuth token misuse, and supply-chain compromise. These techniques enabled access to sensitive customer and business data by **abusing legitimate access paths and delegated trust**. Recent threat activity further highlights how adversary-in-the-middle phishing can undermine MFA protections at the identity provider layer,

reinforcing how Salesforce environments **inherit risk from upstream identity decisions** even in the absence of platform vulnerabilities.

WithSecure Cloud Protection for Salesforce detection telemetry reinforces this perspective, showing a growing prevalence of **URL-driven threats delivered through routine business workflows**, including embedded links and QR code lures. These attacks increasingly blend into expected operational activity and extend beyond file-based malware, with **files most often acting as containers for malicious links** rather than the threat itself.

At the same time, Salesforce continued to expand its platform capabilities through automation, agent-based execution, and AI-driven workflows. While these capabilities deliver significant business value, they also introduce new security considerations. For

instance, identity risks increasingly manifest not only at login time, but also through **delegated, persistent, and non-human execution contexts**.

This report analyses the Salesforce threat landscape in 2025 using WithSecure Cloud Protection for Salesforce detection telemetry alongside publicly disclosed incidents. It examines why Salesforce data has become a high-leverage target, documents key attack paths observed during the year, and assesses emerging risks introduced by automation and agent-based capabilities. The report concludes with **governance-aligned defensive considerations** for teams responsible for Salesforce integration, oversight, and risk management.



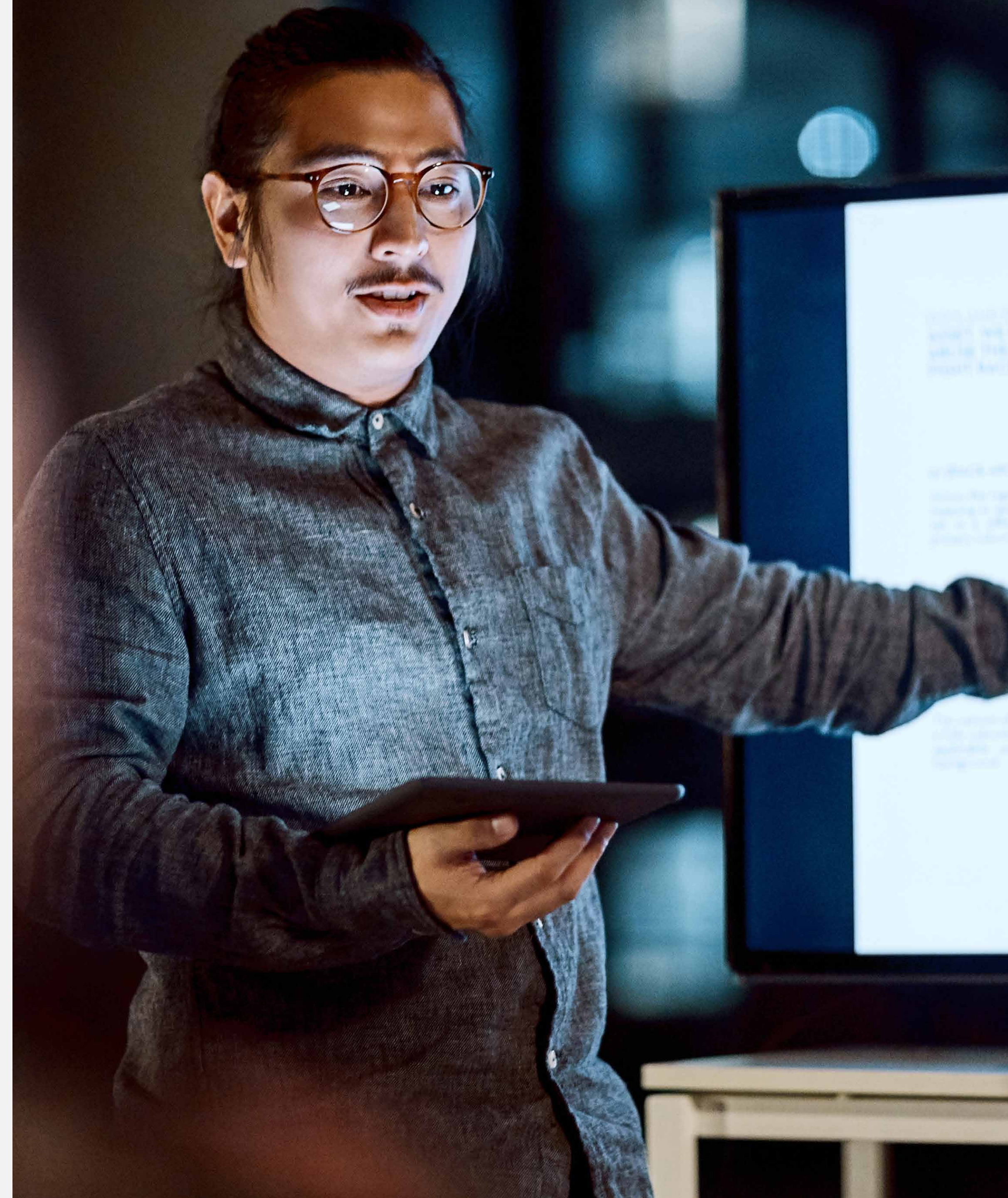
Karmina Aquino
Head of Threat Intelligence,
*WithSecure Cloud Protection
for Salesforce*

AUTHOR

Salesforce Data as a High-Leverage Target

Salesforce has evolved far beyond its origins as a customer relationship management platform. For many organizations, it now functions as a central system of record for customer data, revenue operations, contractual relationships, and support workflows. Salesforce environments are deeply integrated with internal systems, cloud services, and third-party vendors through APIs and OAuth-based authorization mechanisms.

This evolution has expanded both the value and the attack surface of Salesforce. While traditional enterprise security models focused on perimeter defences and endpoint compromise, Salesforce environments expose data primarily through identity, application trust, and automation.



Extortion Economics and High-Trust Access Paths

Modern cybercrime is mostly financially driven. Threat actors increasingly prioritize techniques that maximize leverage while minimizing operational cost and exposure per intrusion. Extortion economics favour data theft over service disruption.



Due to this, attackers seek platforms that:

- Store sensitive and regulated data
- Are critical to business operations
- Cause pressure through legal, regulatory, or reputational consequences



Salesforce environments align closely with these criteria. They commonly contain:

- Personally identifiable information (PII) governed by GDPR, CCPA, and similar regulations
- Sales forecasts, pipeline data, and contractual and pricing information
- Customer communications and support records

Access to this data enables attackers to apply pressure without the need to deploy ransomware nor to disrupt systems.



Salesforce also presents attackers with attractive operational characteristics:

- API-driven access that blends into normal business activity
- OAuth tokens that bypass interactive authentication
- Integration models that assume long-term trust

These reduce the chances of immediate detection and increase dwell time once access is obtained.

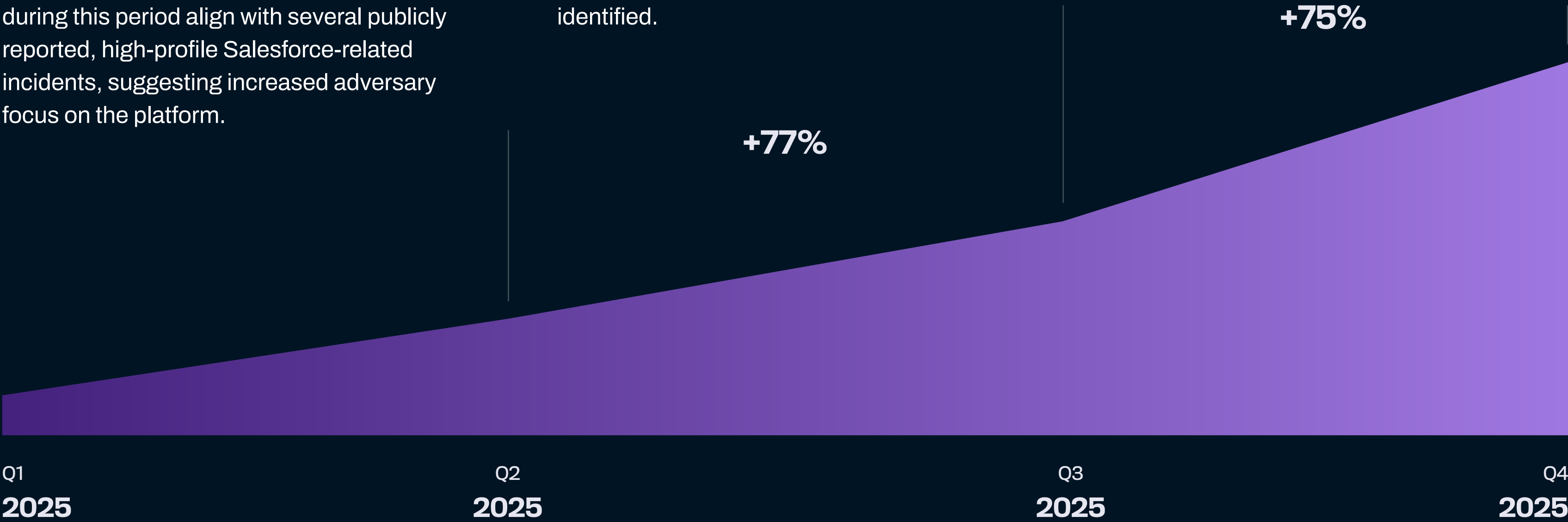
WithSecure Cloud Protection for Salesforce: Detection Telemetry and Threat Patterns

Malicious Detection Rates Observed in 2025

Based on telemetry from WithSecure Cloud Protection for Salesforce, malicious detection activity increased consistently throughout 2025, with growth accelerating in the second half of the year and reaching a level in Q4 that was **approximately eight times higher than in Q1** when measured across all scans.

The acceleration was most evident in Q3 and Q4, possibly reflecting a combination of heightened attacker activity, broader detection coverage, and introduction of new detection mechanisms. Detections during this period align with several publicly reported, high-profile Salesforce-related incidents, suggesting increased adversary focus on the platform.

The observed upward trend also indicate improvements in detection visibility over time, as additional detection logic and coverage enabled threats that may previously have gone unnoticed to be identified.

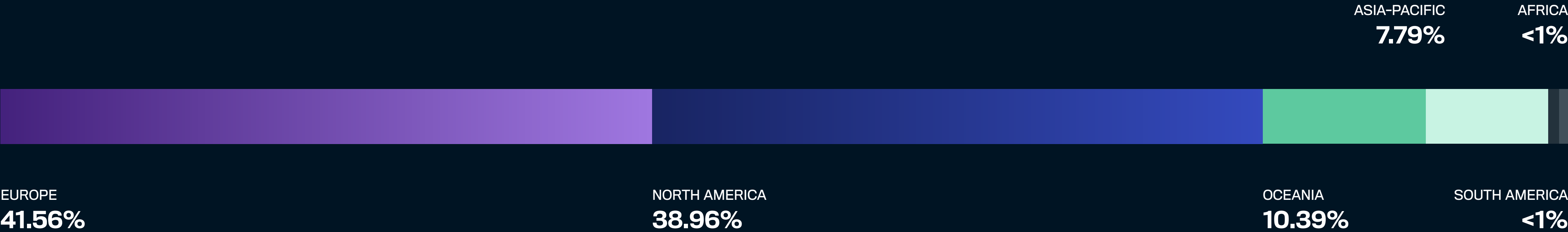


Geographic Distribution of Affected Organizations

Organizations that experience malicious detections during 2025 were distributed across all major geographic regions, indicating that malicious activity targeting Salesforce environments was not confined to a specific location. Affected organizations were observed in North America, Europe, Asia-Pacific, and other regions, underscoring the global nature of the threat activity captured in the telemetry.

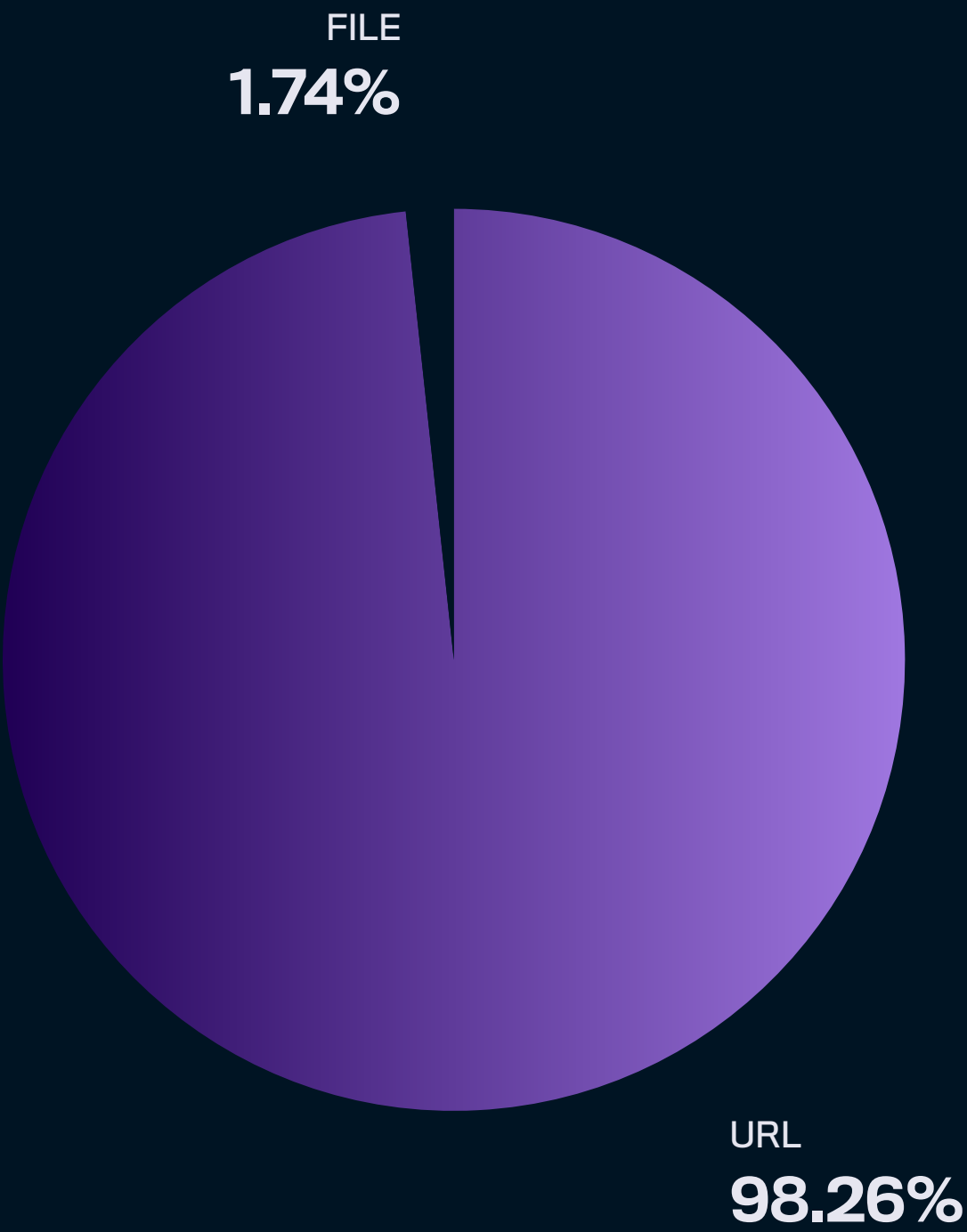
While malicious detections were observed worldwide, a significant share of affected organizations was concentrated in a small number of countries. The three most frequently affected countries during 2025 were the United States, the United Kingdom, and Australia, which together accounted for approximately 53.5% of affected organizations. All three are primarily English-speaking regions.

This pattern may reflect the prevalence of attack techniques such as phishing, which often rely on language and impersonation of trusted services.



Distribution of Malicious Detections by Content Type

Most malicious detections observed in 2025 were associated with URLs rather than files. **Approximately 98% of all malicious detections were URL-based**, while file-based detections accounted for a comparatively small share of observed activity. This distribution indicates that malicious activity targeting Salesforce environments during this period relied primarily on web-based delivery mechanisms rather than file-borne malware.



Observed Patterns in Malicious URLs

Analysis of malicious URLs observed in Salesforce environments during 2025 shows that attacker infrastructure spanned a wide range of domain ages. Newly registered domains were commonly associated with **fast-moving phishing campaigns**, while longer-lived domains were often **reused or repurposed** to support multiple attack efforts. This highlights the importance of using domain age as part of a broader set of URL evaluation signals.



Domain Age Distribution (Days)

In many cases, even when the underlying domain persisted over time, the specific URLs or subdomains used for malicious activity were short-lived. Attackers frequently rotated these components to support individual campaigns, limit exposure, and evade simple blocking approaches.

Across all observed age ranges, malicious domains frequently followed similar naming patterns, including:

- Programmatically generated domains containing high-entropy strings
- Domains constructed from randomly combined, dictionary-style words
- Domains that combine random elements with well-known brand names or account-related terms

Taken together, these observations show that malicious URL infrastructure spans both newly registered and longer-lived domains, reflecting different operational approaches attackers use to blend into routine business activity over time.

Observed Patterns in Malicious Files

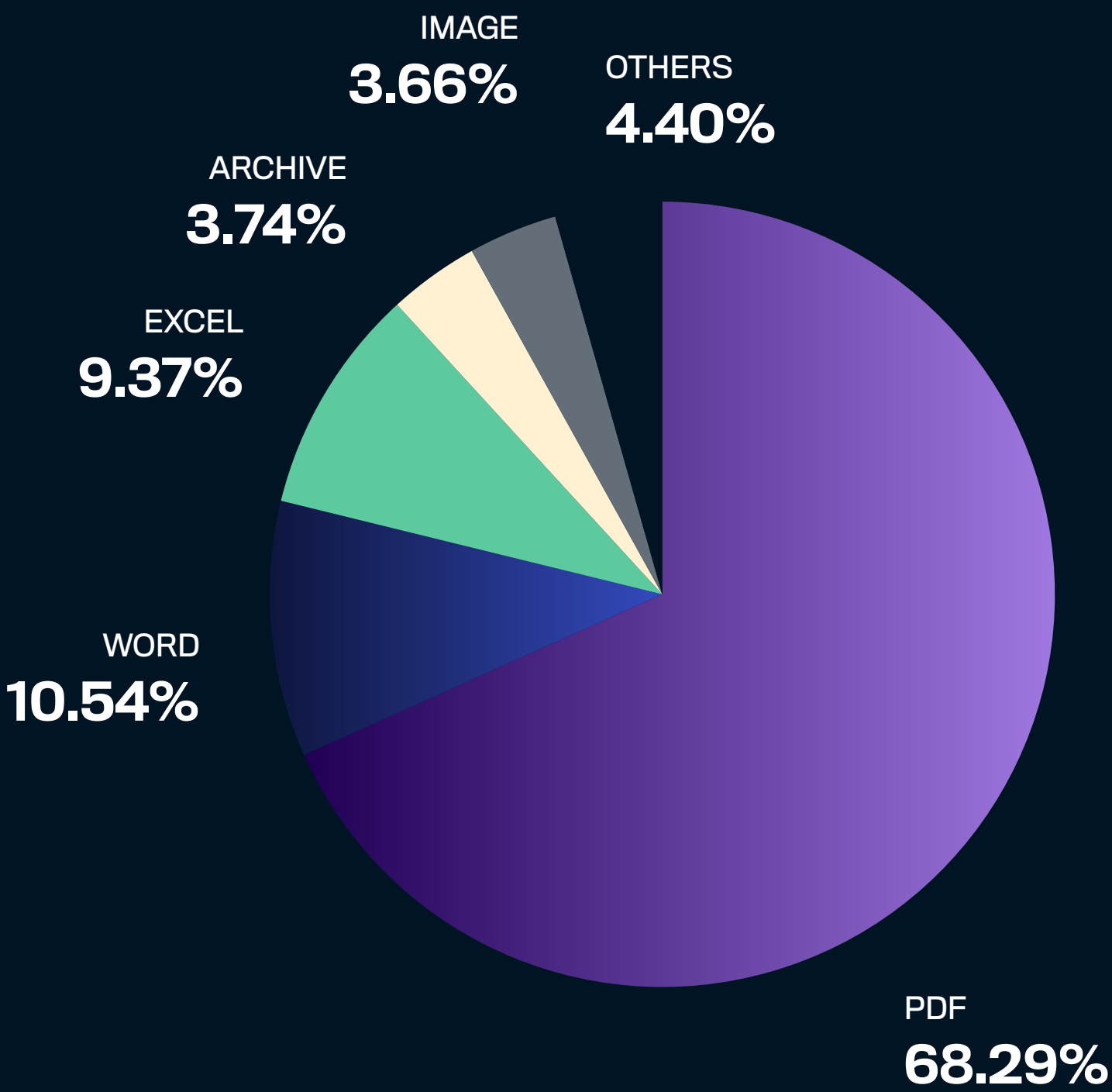
Among malicious file detections, PDF documents accounted for the largest share, followed by Microsoft Word and Excel files, with smaller proportions associated with archive formats, images, and other file types. These formats closely resemble common enterprise documents routinely exchanged through Salesforce-related workflows.

Notably, **approximately 98.9% of malicious file detections involved embedded malicious URLs** contained within otherwise legitimate-looking documents. Rather than serving as malware delivery mechanisms themselves, files overwhelmingly functioned as trusted containers for URL-based attacks. This pattern highlights how attackers continue to favor web infrastructure and social engineering, even when using files as an intermediate step to introduce malicious content.

Detection telemetry also included **instances of highly targeted social engineering**, where malicious documents

and embedded URLs were tailored to closely resemble the templates, workflows, and service endpoints of the target organizations. In these cases, attackers used professionally branded documents and URL structures that mimicked legitimate enterprise services, despite being hosted on attacker-controlled domains. This level of fidelity suggests prior reconnaissance and reflects an intent to blend malicious content seamlessly into the organization’s normal operational context.

These findings reinforce that URL-based threats remain the dominant driver of malicious activity observed in Salesforce environments in 2025. Files, while less frequently identified as malicious, can still serve as an effective conduit for URL-based attacks, particularly when embedded links are used to redirect users to credential-harvesting or malicious web content.



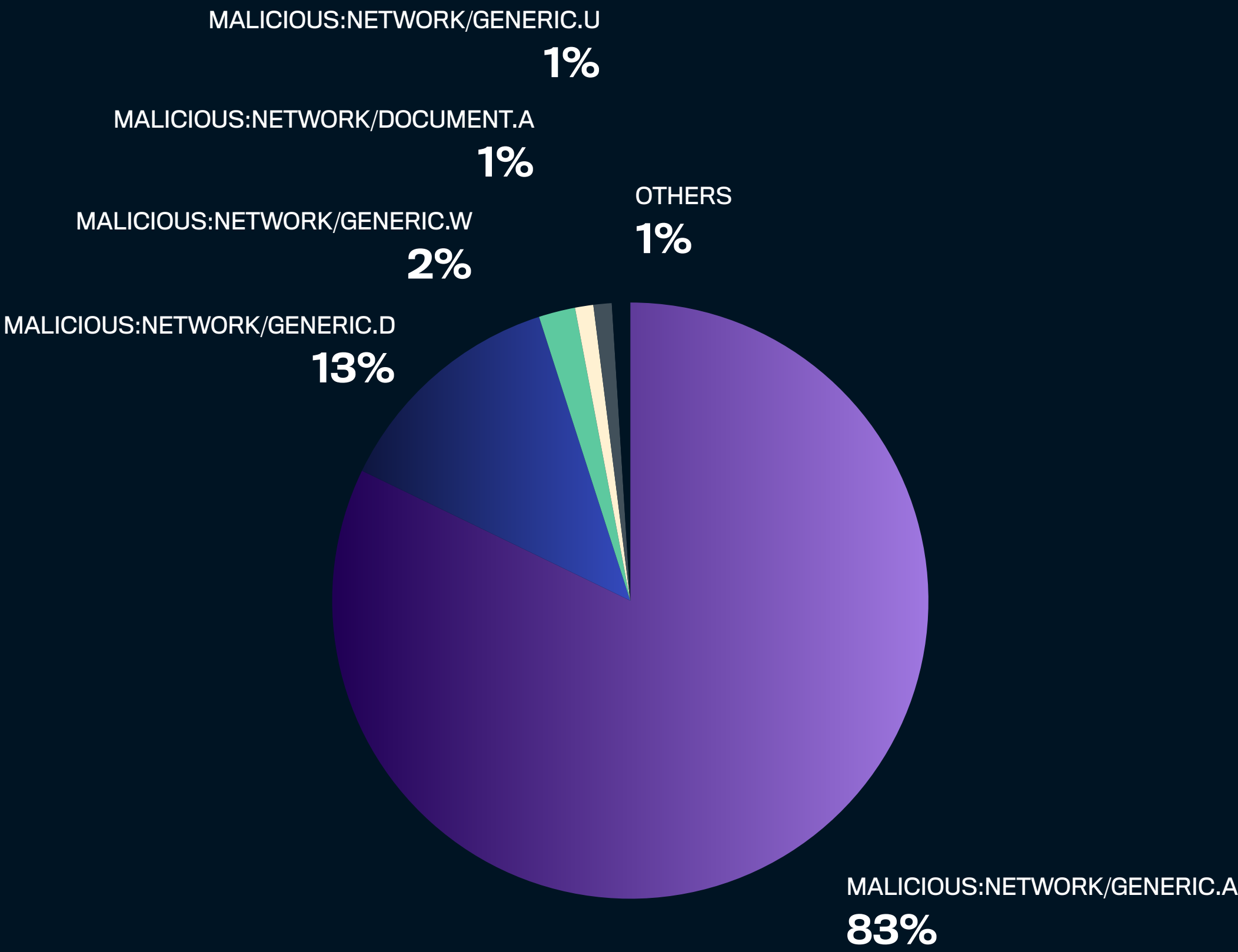
Top Detections Observed in 2025

Approximately **95% of malicious files and URLs detected in 2025 were identified using just two detection types**. These dominant detections were primarily associated with malicious URLs used in social engineering, phishing, and credential-harvesting campaigns. In other cases, detected URLs pointed to infrastructure hosting malicious content, including sites used for drive-by downloads, delivery of malicious binaries, or command-and-control activity. The prevalence of these detections reflects the continued reliance on web-based infrastructure that can be rapidly deployed, modified, and reused across multiple campaigns.

Nearly all malicious document detections involved embedded malicious links. In these cases, the document acted as an initial delivery mechanism, with URLs identified during file analysis rather than through direct user interaction. Attackers commonly use this approach because document attachments are typically

perceived as legitimate business artifacts, and links embedded within documents often appear less suspicious than standalone URLs, increasing the likelihood that they will be trusted and acted upon.

The distribution of top detections reinforces a consistent theme observed throughout 2025: malicious activity targeting Salesforce environments was largely driven by URL-based threats, whether delivered directly or indirectly through documents.



Examples of Observed Malicious Content

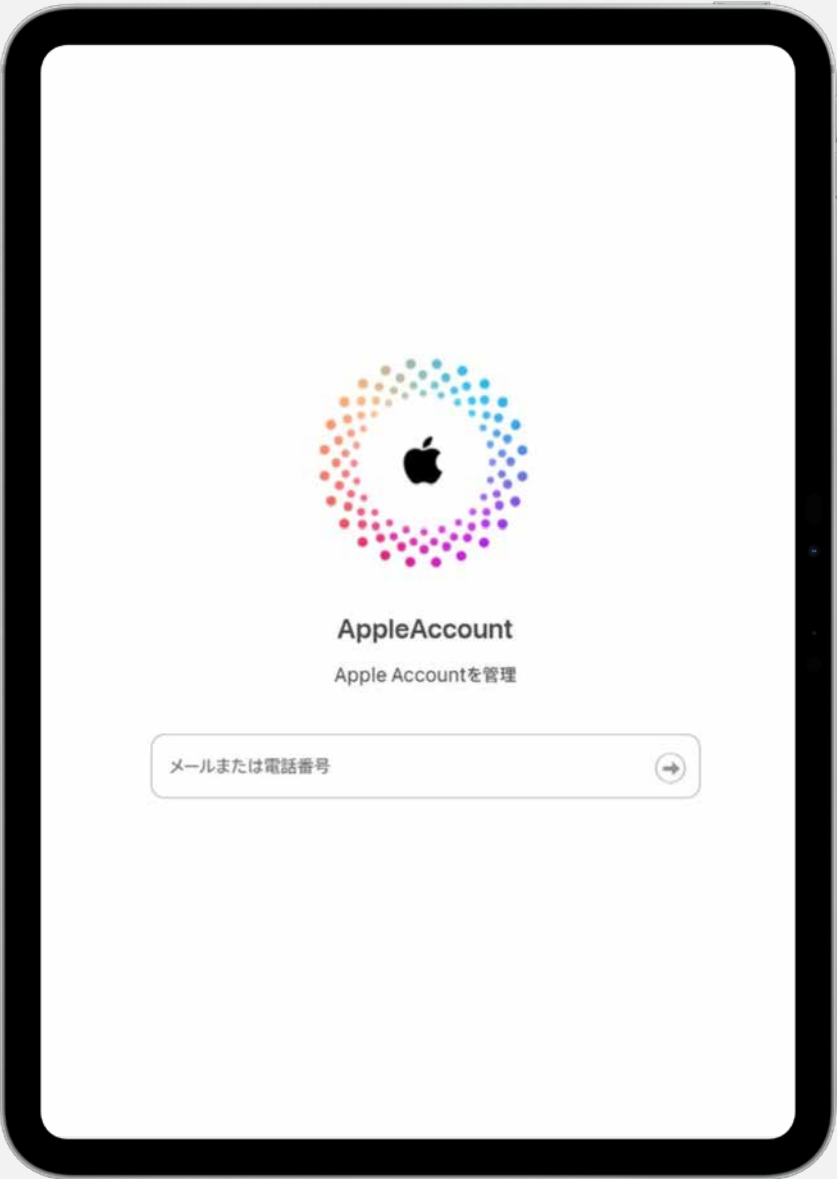
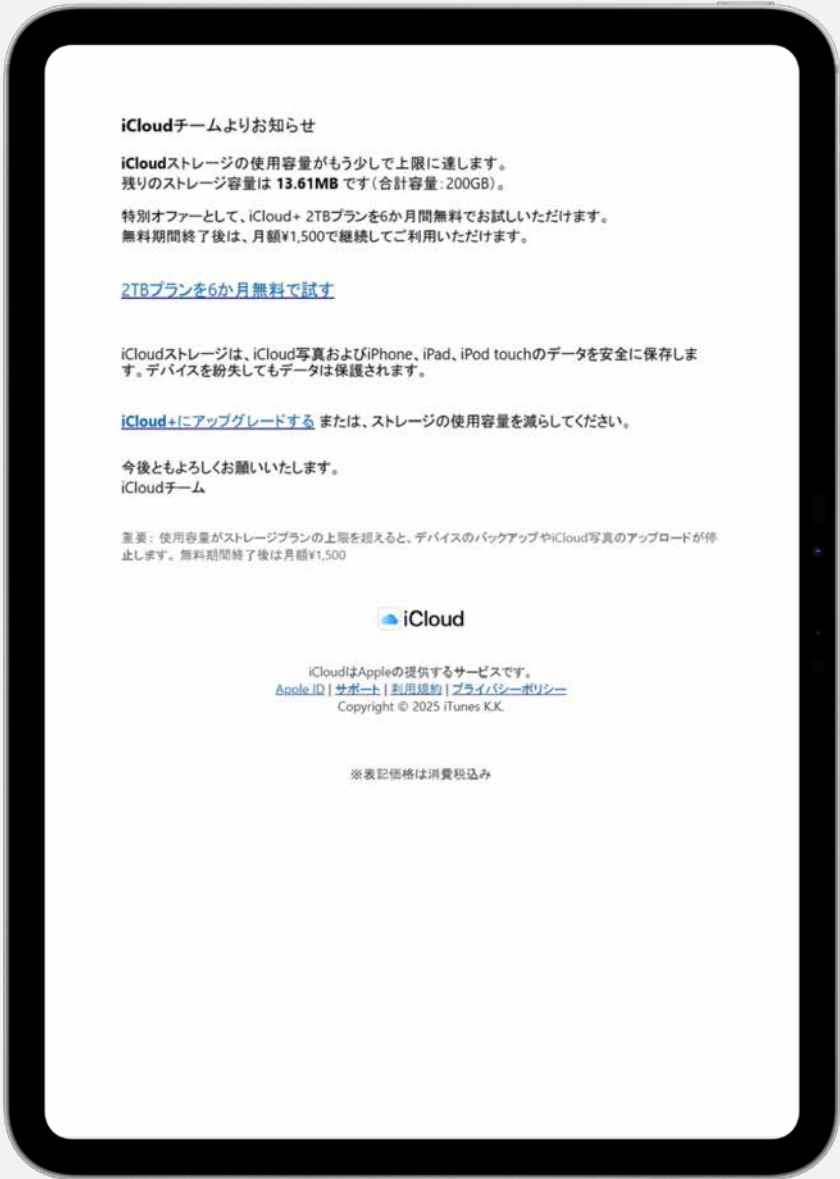
The following examples illustrate how these dominant detections manifested in real-world attacks observed from WithSecure Cloud Protection for Salesforce detection telemetry during 2025.

Cloud Storage Phishing



Malicious:Network/Generic.A

This detection triggered due to a URL from a phishing message impersonating a legitimate iCloud storage notification, warning recipients that they are nearing their storage limit. The message prompts users to follow a link to upgrade their plan, which redirects to a credential-harvesting page masquerading as an Apple login portal.



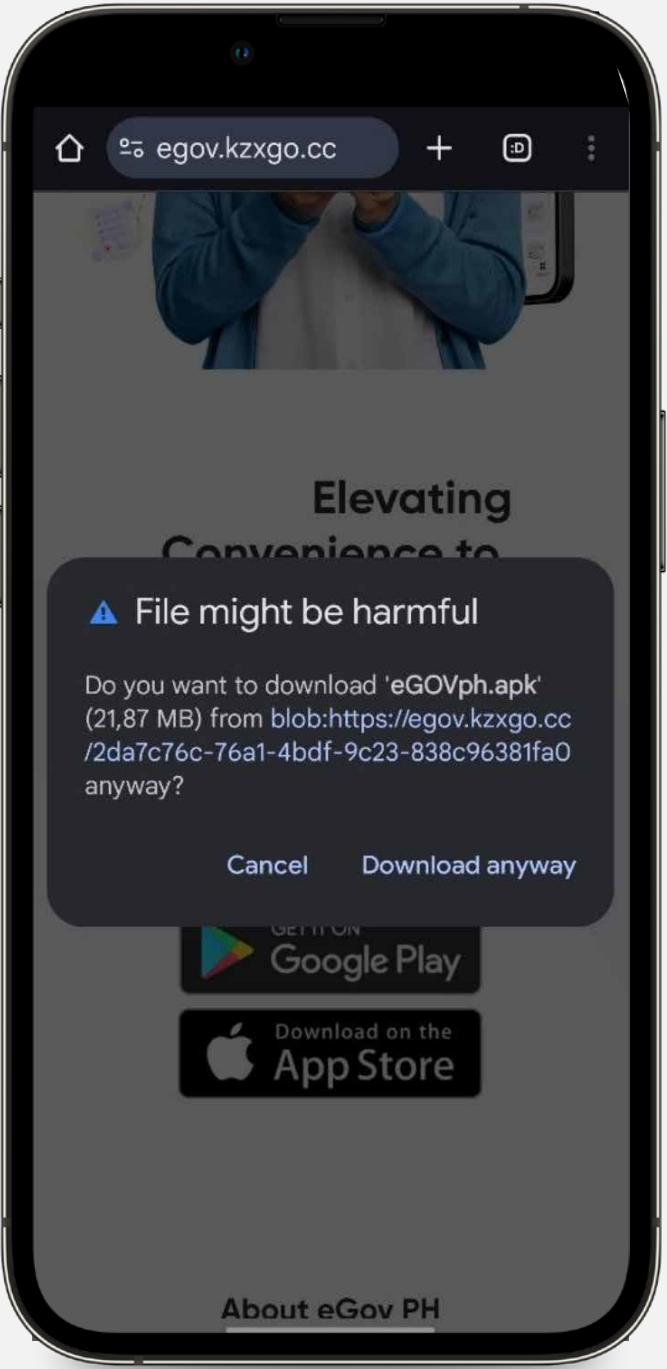
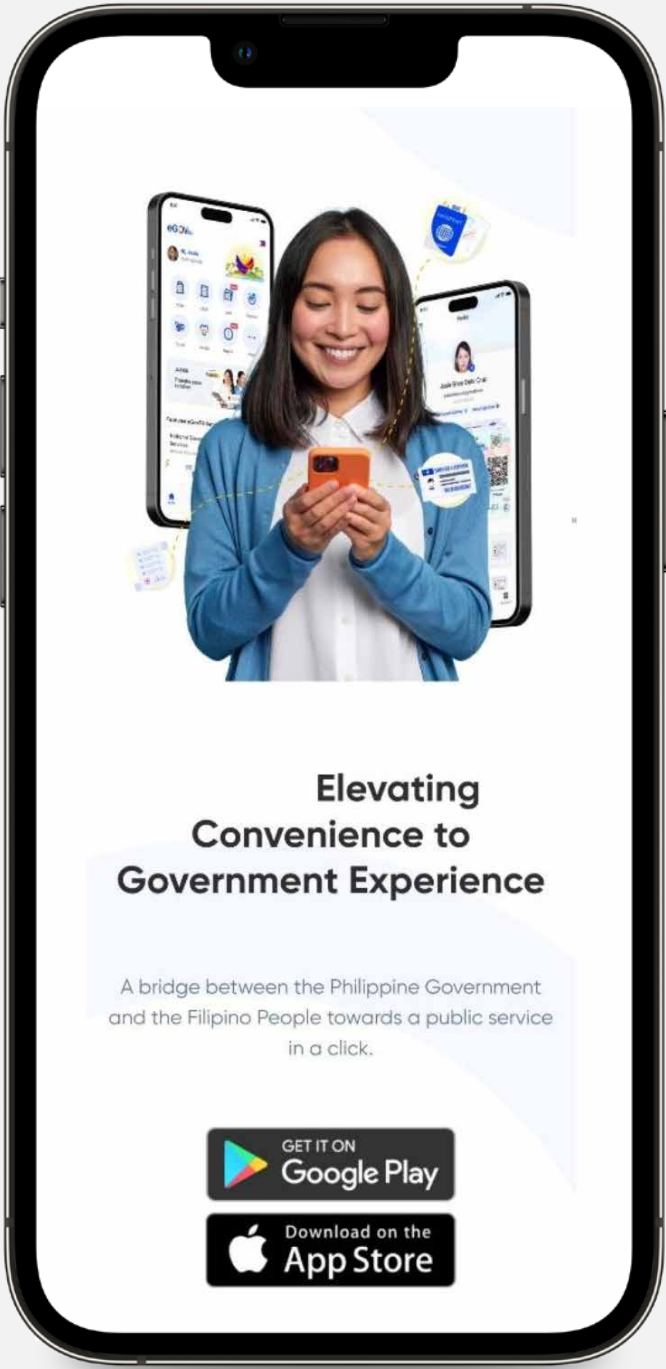
Fake iCloud storage notification leads to a phishing page

Malicious Application Delivery Site



Malicious:Network/Generic.D

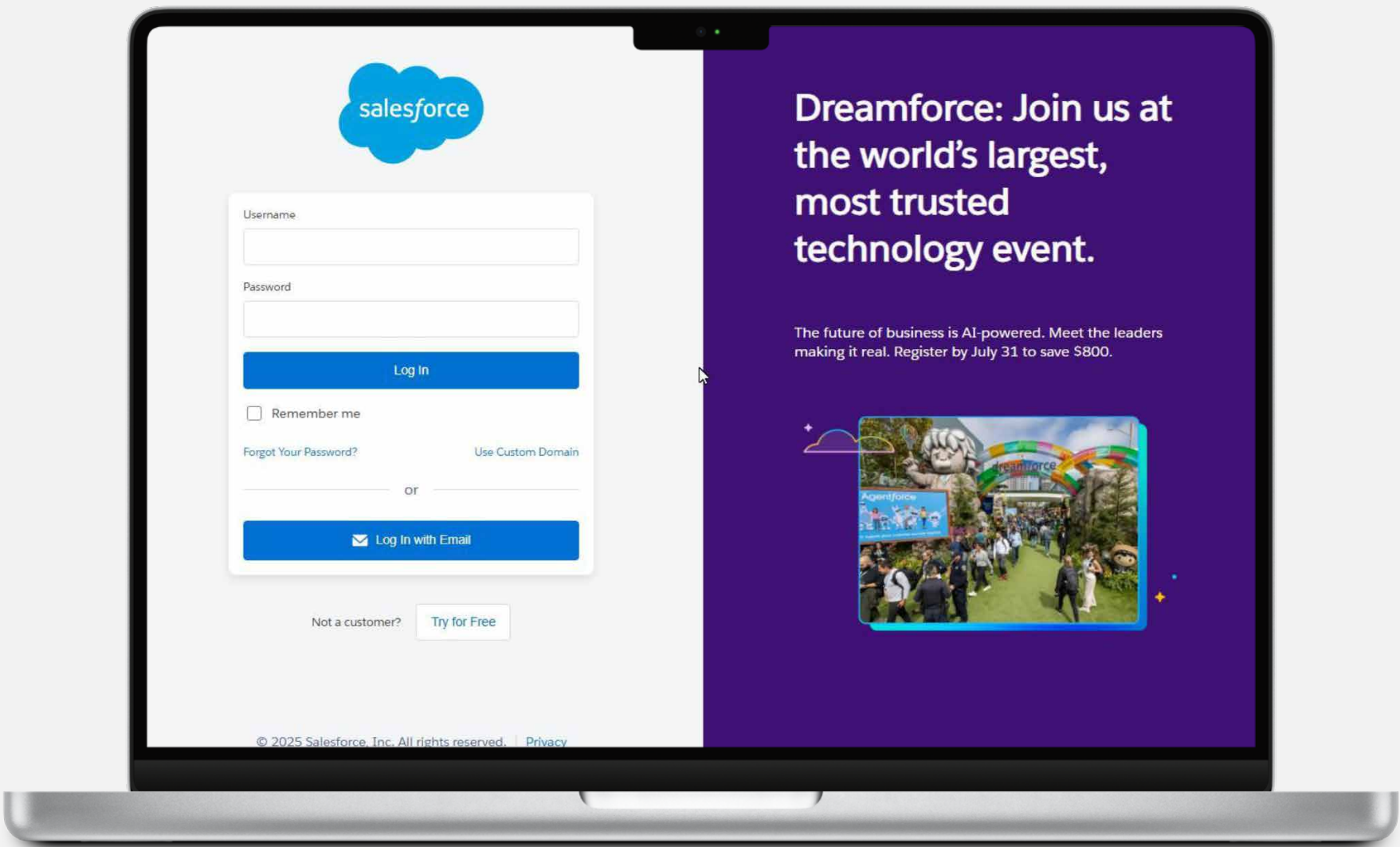
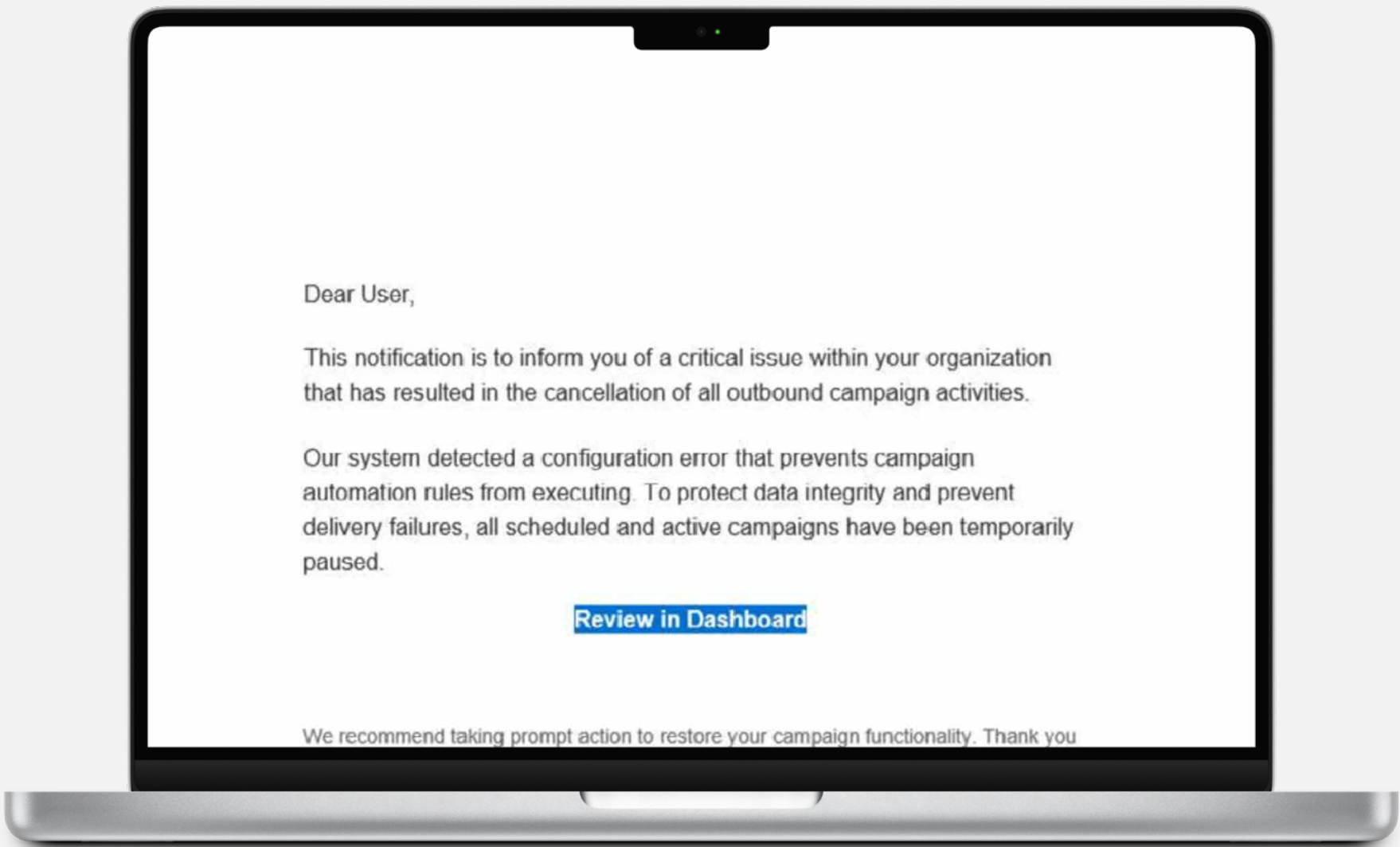
This detection triggered due to a URL that prompted users to download a mobile application package from an untrusted source. The malicious app from this URL spies on user activities, collects personal information such as the user’s contacts, SMS messages, call logs, and device information, and uploads this data to the attacker’s command-and-control server.



User is led to a website hosting malicious apps

Multi-stage Salesforce Phishing

This detection also triggered due to a URL from a phishing email impersonating a Salesforce notification, prompting recipients to review an issue via an embedded link. The link redirects to a fraudulent Salesforce login page designed to collect credentials and subsequently presents a fake multi-factor authentication prompt, enabling attackers to capture additional authentication information.



Phishing email link leads to a fake Salesforce login page

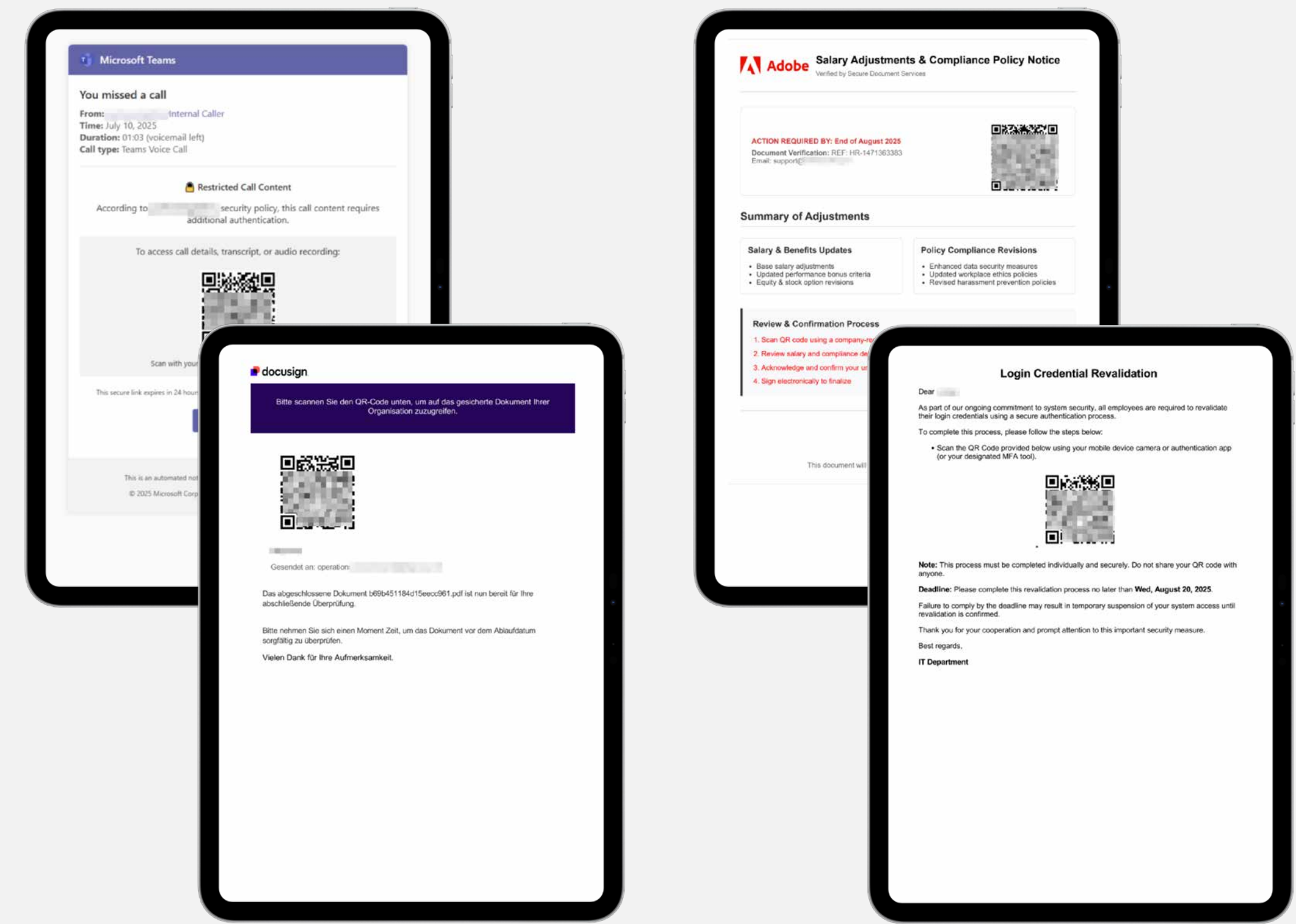
Adversary-in-the-Middle (AitM) Quishing Campaign

Detection telemetry from 2025 shows sustained activity associated with QR code phishing or quishing campaigns that leveraged adversary-in-the-middle (AitM) techniques to compromise user identities. These were commonly delivered through email and other routine business communications, using QR codes to **shift user interaction away from traditional links**.

The observed campaigns primarily used QR codes embedded in messages that mimicked routine enterprise communications impersonating trusted internal departments or widely used third-party services to increase credibility. Common lures included notifications related to:

- Confidential document delivery
- Internal policy updates
- Account or login revalidation requests
- Compensation or payment-related messages
- Missed communications such as voicemail or fax alerts

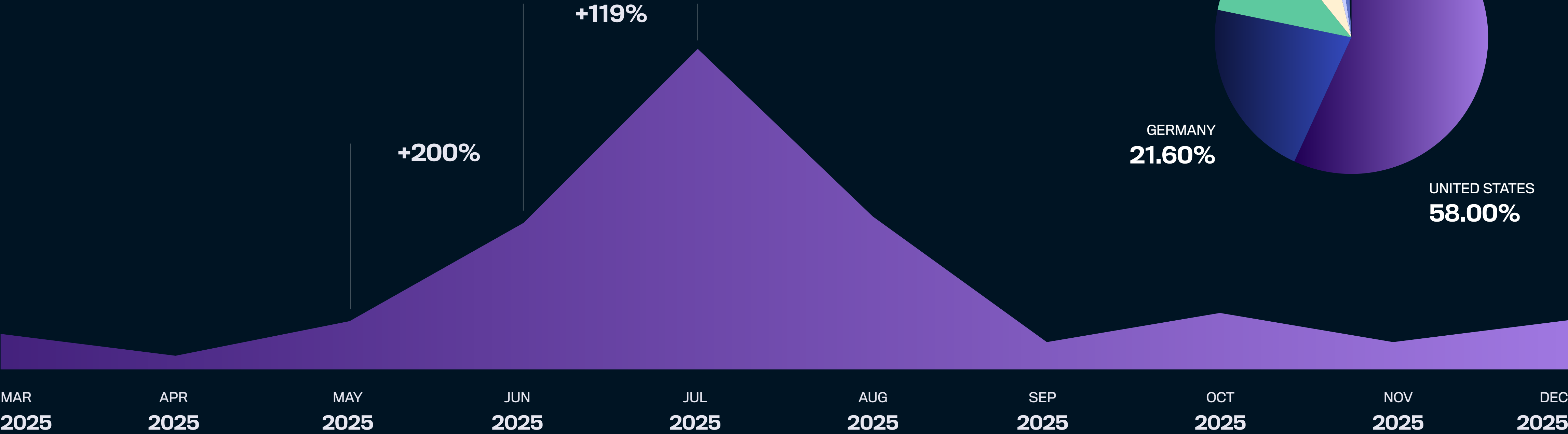
By prompting users to scan codes with mobile devices, attackers reduced visibility into the destination URL and **bypassed many traditional endpoint and email security controls** that focus on link inspection. This shift also moved the authentication flow away from the original device, complicating detection and response.



Examples of actual quishing documents

AitM Quishing Trend

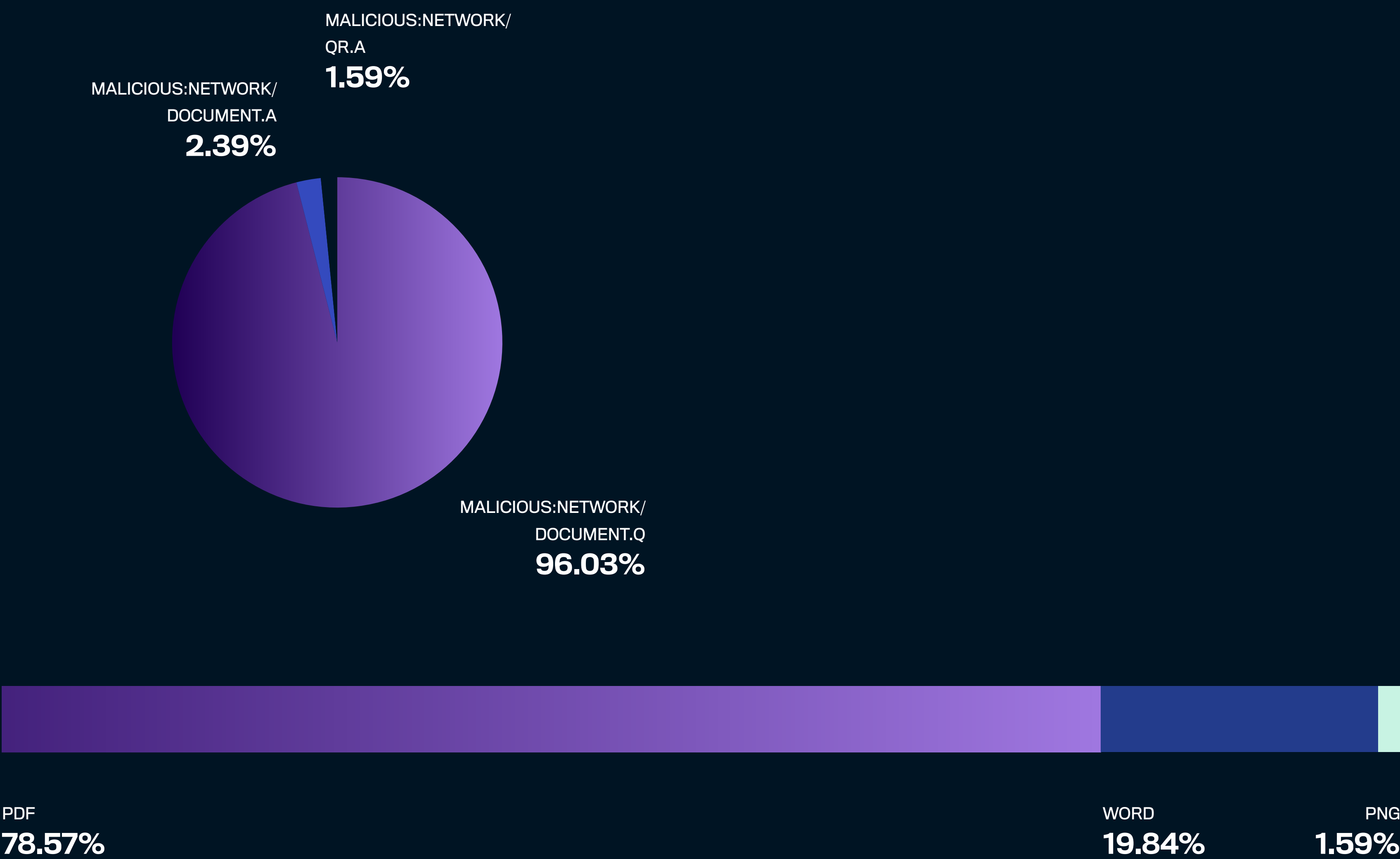
Telemetry indicates that these campaigns were most active during mid-2025, with a **clear spike observed in July**, followed by continued activity at lower levels through the remainder of the year. Affected organizations were distributed across multiple regions, with the highest concentration observed in the United States. Detection coverage for these campaigns primarily included signatures associated with embedded QR codes and embedded links within documents, reflecting the delivery mechanisms used.



AitM Quishing Detections

Telemetry associated with these quishing campaigns also showed a clear preference for document-based delivery. The majority of file-based detections linked to QR phishing activity involved PDF documents, followed by Microsoft Word files, with PNG appearing only rarely. These formats align closely with routine enterprise document workflows and are well suited for embedding QR codes or links while appearing legitimate to recipients.

The use of **commonly trusted document types reinforces the social engineering aspect** of these campaigns, allowing attackers to introduce malicious QR codes into Salesforce environments through files that resemble standard business communications rather than overtly suspicious content.

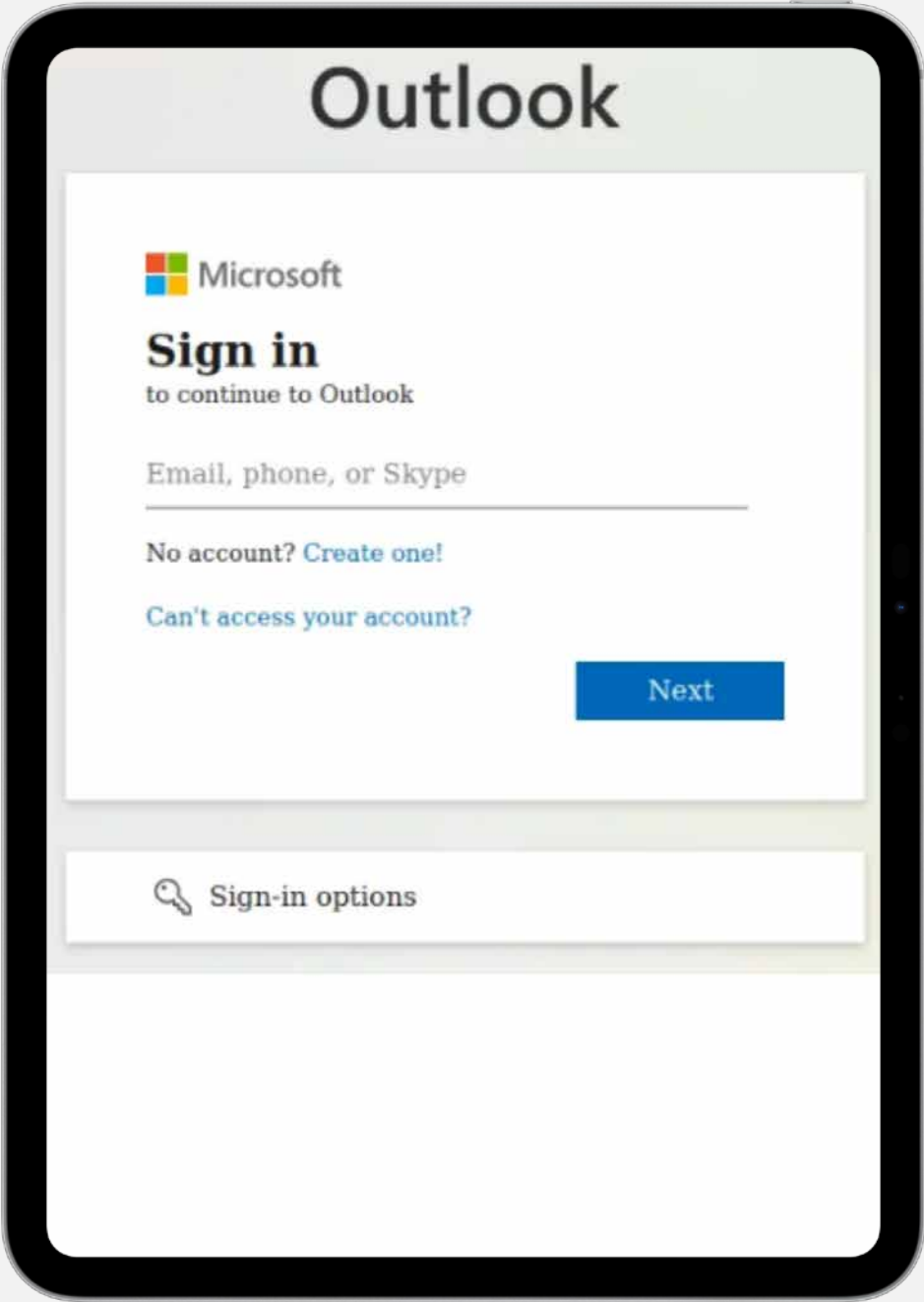
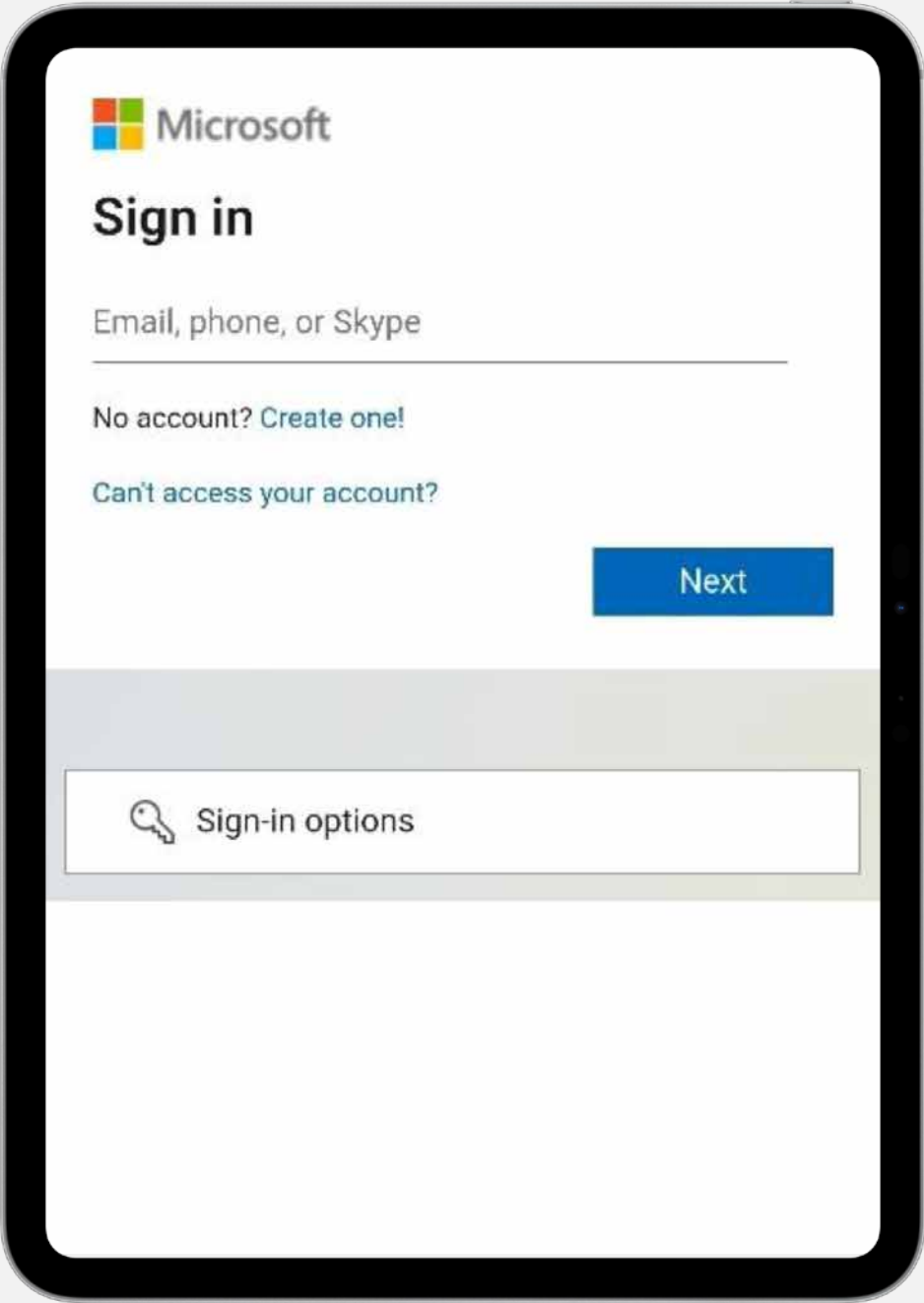
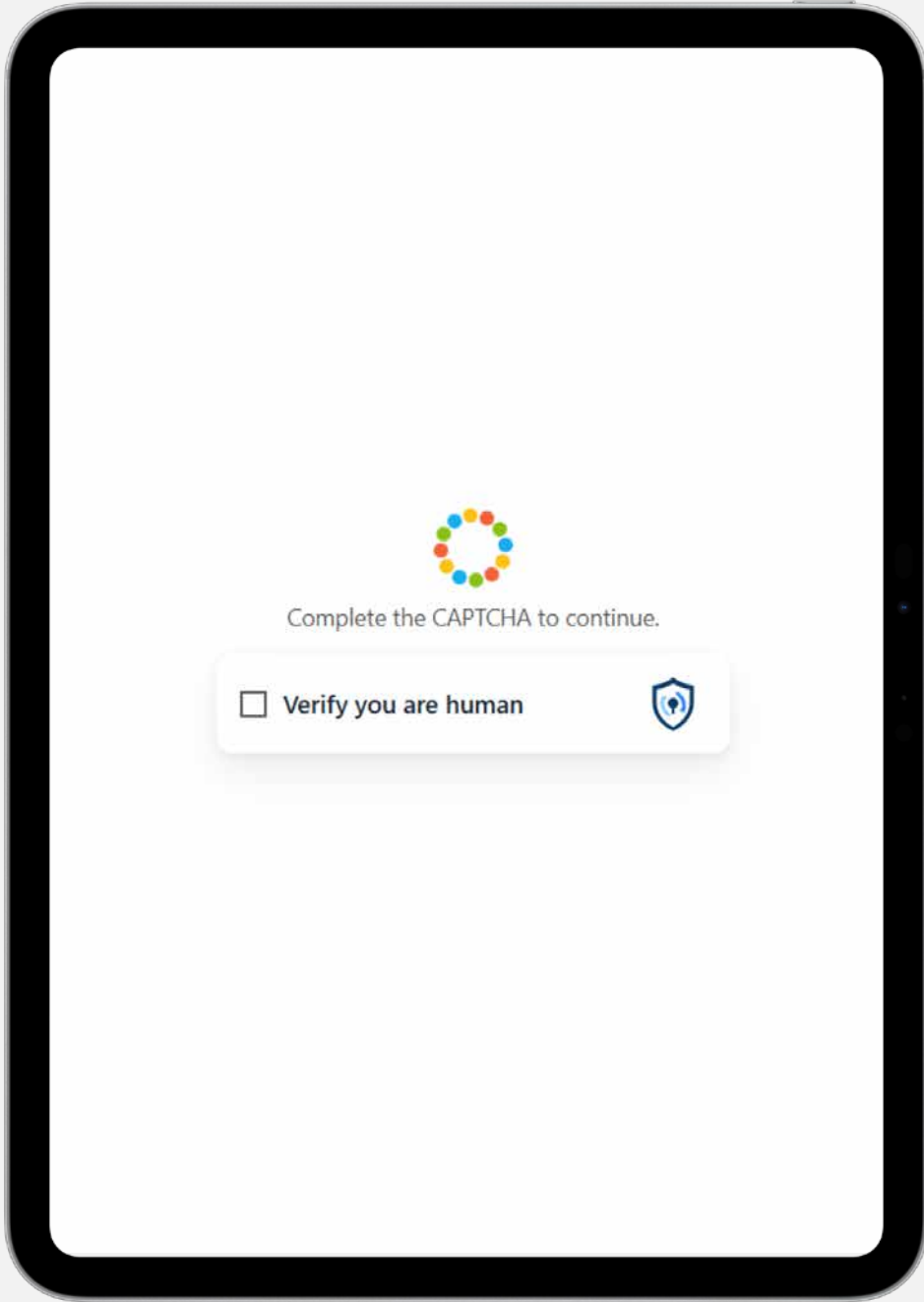


Use of AitM Phishing Infrastructure

Analysis of detected samples indicates the use of the commercially available AitM phishing kit commonly referred to as “Tycoon 2FA.” This kit operate as a **phishing-as-a-service offering and is designed to intercept authentication flows in real time.**

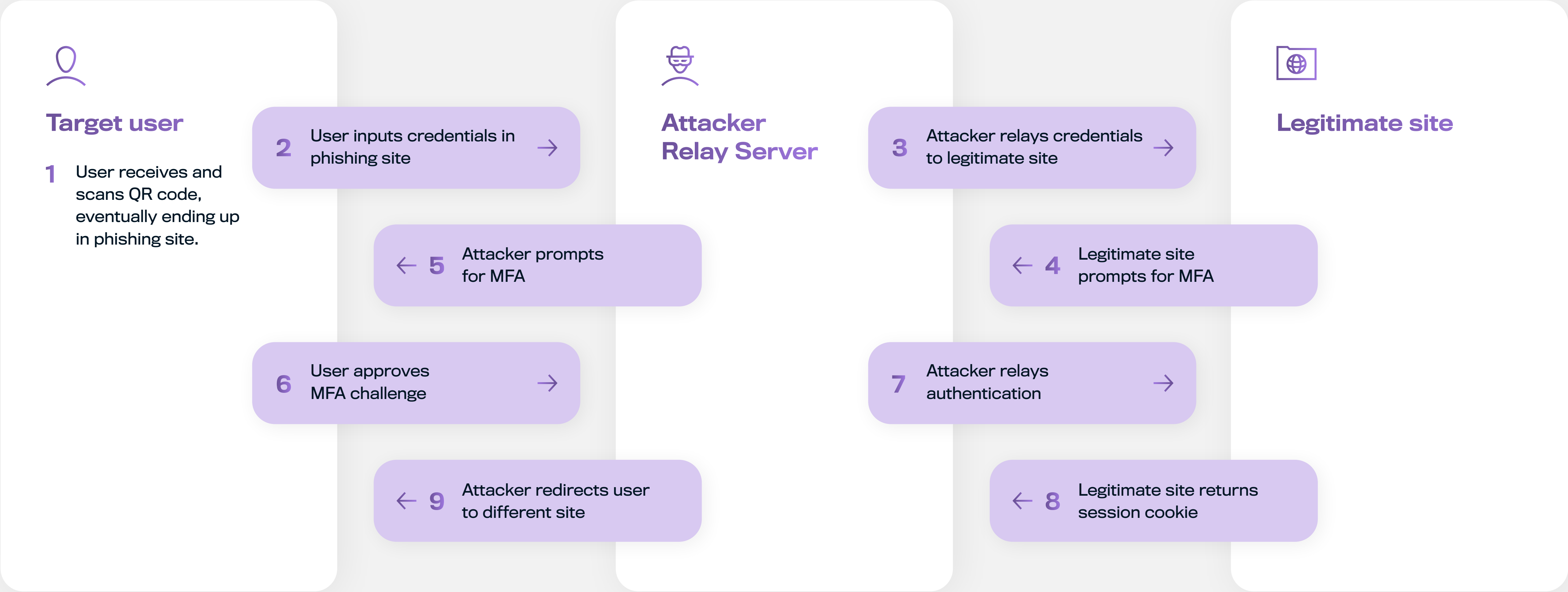
Rather than simply collecting usernames and passwords, AitM kits proxy authentication requests between the victim and the legitimate service. When users enter credentials and complete multi-factor authentication, the kit **captures session cookies generated during the process.** Possession of these session cookies allows attackers to access accounts without requiring further authentication, effectively bypassing MFA protections.

To reduce exposure to automated detection and analysis, the **observed infrastructure implemented multiple pre-interaction checks.** These included CAPTCHA challenges, checks for automated scanners and known analysis tools, and environment checks designed to avoid security researchers or sandboxed environments. Only after these checks were satisfied would the phishing flow proceed.



Captcha leads to fake login pages, such as:

AitM Quishing Attack Flow



Implications for Salesforce Environments

Although the initial credential compromise occurs outside Salesforce, successful AitM phishing can enable subsequent access to enterprise systems that rely on federated identity, OAuth-based authorization, or trusted session reuse. In Salesforce environments, this may lead to unauthorized access, data exfiltration, or follow-on social engineering activity using compromised accounts.



Publicly Reported Incidents

In 2025, multiple publicly reported security incidents indicated that organized cybercriminal groups increasingly targeted Salesforce environments. In these cases, attackers leveraged identity abuse, OAuth authorization mechanisms, and trusted third-party integrations to gain access to Salesforce data, often with the intent to monetize or exert pressure through data exposure.



Identity-Based Access Abuse (Gehenna)

Timeline:

Disclosed in May 2025

Initial Access Vector:

Likely identity-based access

Impact:

Bulk data exfiltration and resale in the underground markets

In mid-2025, a threat actor known as Gehenna (or GHNA) publicly claimed to have exfiltrated a large volume of CRM data from an organization’s Salesforce environment. The threat actor **allegedly stole tens of millions of CRM records** containing data such as account and contact information and customer support case logs. Gehenna published samples of this data on the dark web forums to illicit data trading and negotiation.



OAuth Device Flow Authorization Abuse (UNC6040)

Timeline:

Mid-2025

Initial Access Vector:

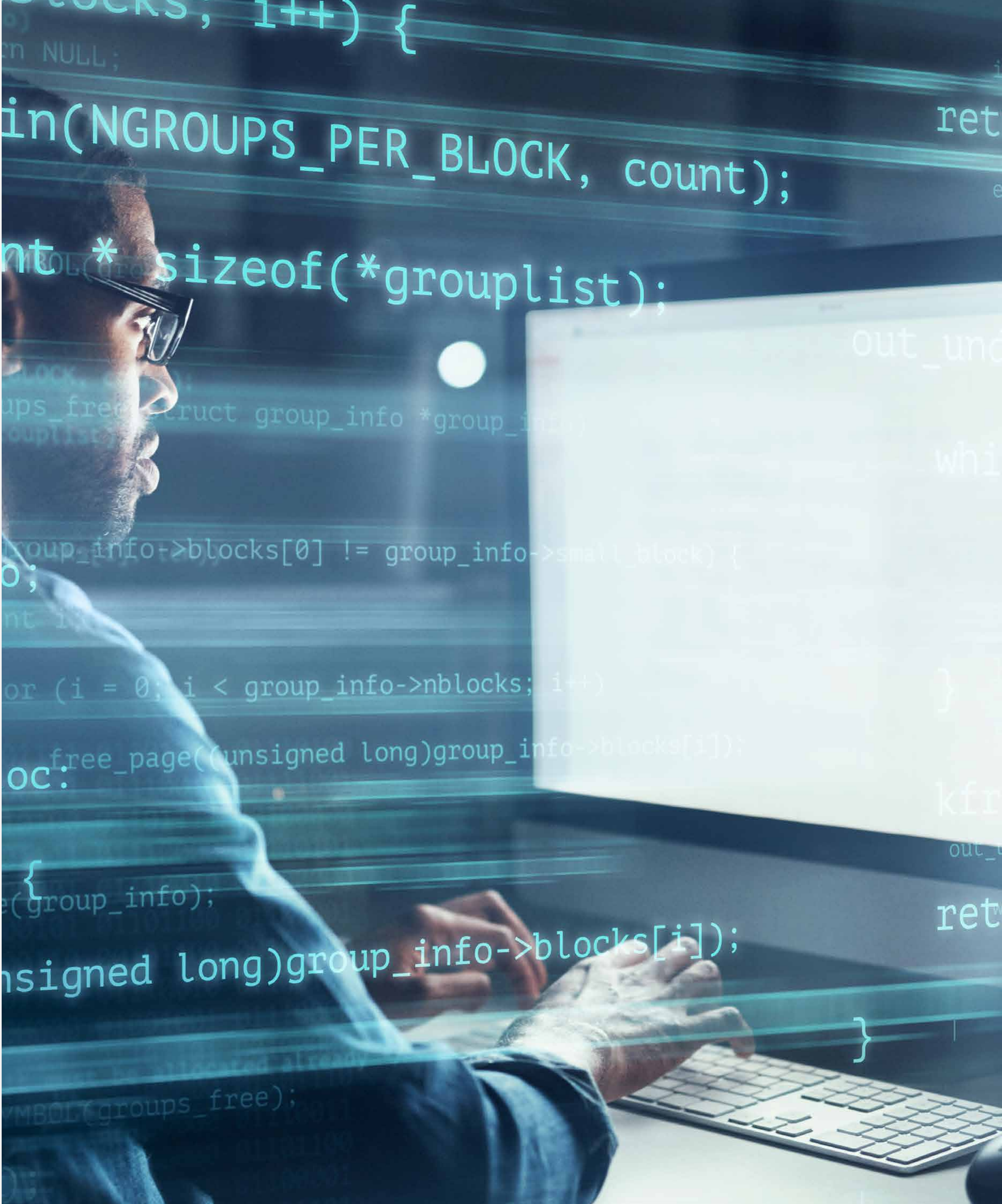
Social engineering leading to OAuth authorization

Impact:

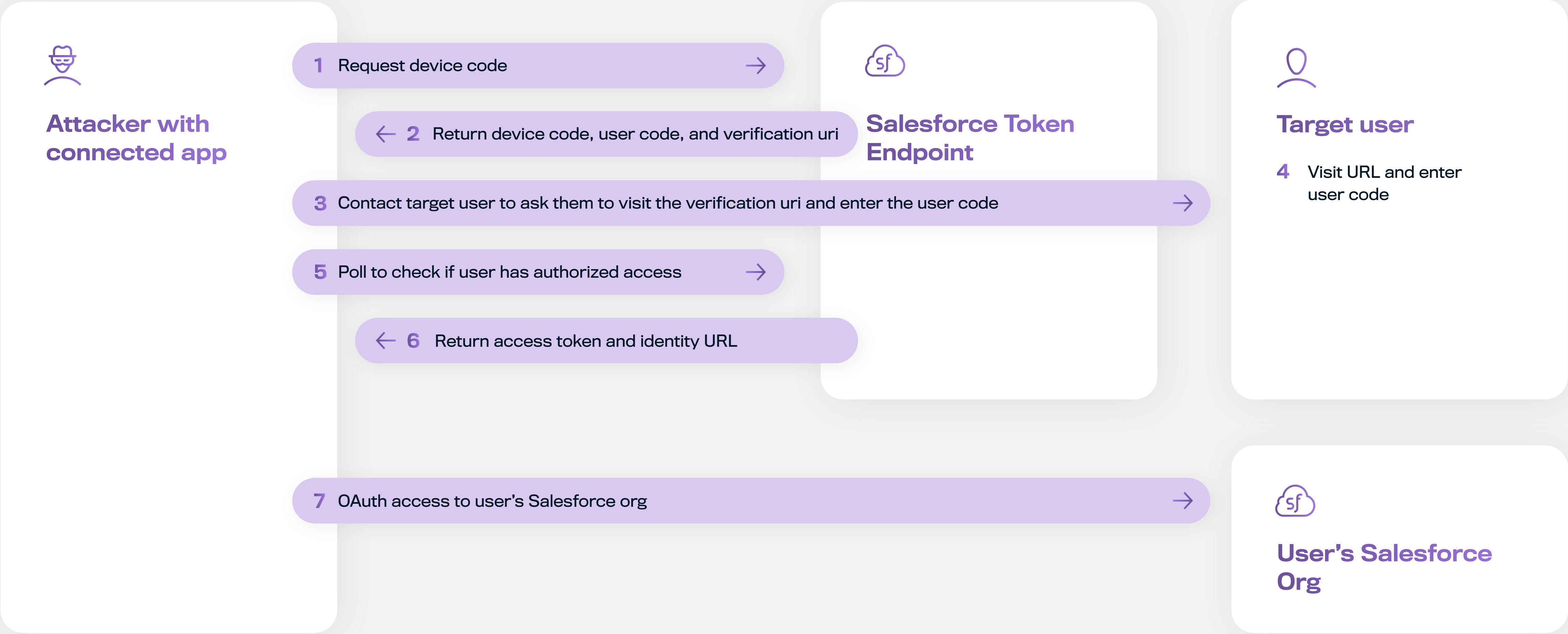
Data exfiltration and extortion through data brokers

Activity attributed to the threat actor group tracked as UNC6040 was observed **compromising multiple large organizations'** Salesforce environments throughout mid-2025 and continuing into late 2025. The group conducted targeted reconnaissance to identify suitable victims and deliberately obscured its activity using VPN and Tor. Data access and exfiltration were staged to minimize detection. Rather than exploiting Salesforce platform vulnerabilities, the actors **relied on legitimate Salesforce tooling and authorization paths**, such

as Data Loader and valid OAuth tokens, allowing their activity to blend into normal operational patterns. Access was obtained by convincing users to authorize attacker-controlled connected applications by abusing the OAuth Device Flow authorization.



Connected App via OAuth Device Flow Attack



Supply-Chain Compromise: Salesloft Drift Integration

Timeline:

March 2025

Initial Access Vector:

Compromise of vendor development infrastructure

Impact:

Unauthorized access to customers' Salesforce data

According to the investigation, unauthorized access to Salesloft Drift's GitHub account occurred between March and June 2025. During this period, the threat actor conducted reconnaissance activity and later **accessed Drift's AWS environment, where OAuth tokens used for customer integrations** were stored. These tokens were subsequently used to access customer Salesforce data through legitimate Drift integrations without the customer's authorization.



Supply-Chain Compromise: Gainsight Integration

Timeline:	October 2025
Initial Access Vector:	Undisclosed
Impact:	Unauthorized access to customers’ Salesforce data

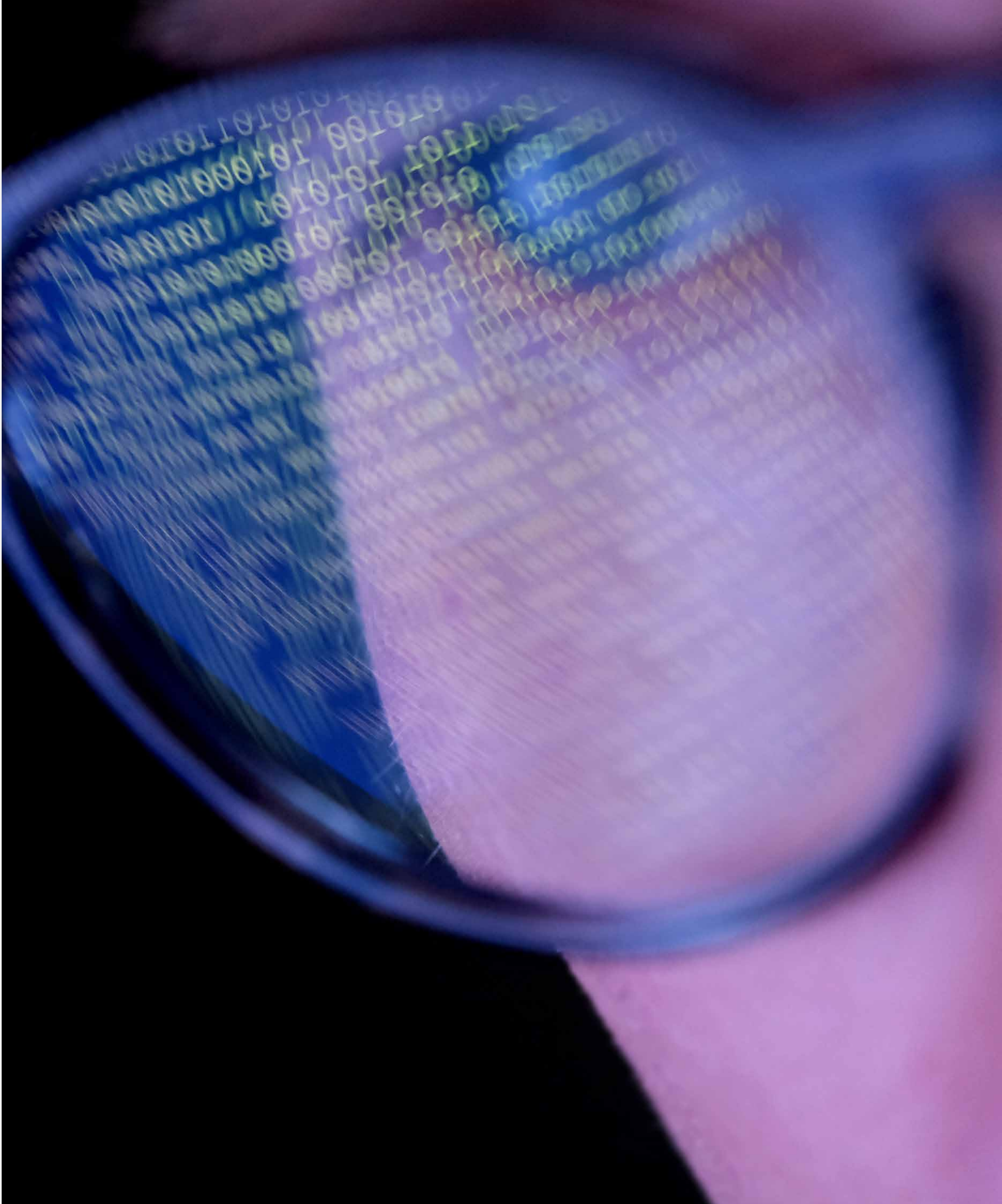
In November, Salesforce observed anomalous behaviour, including reconnaissance against customers associated with compromised access tokens linked to the Gainsight integration. Available indicators suggest that the suspicious activity began late October with **partial overlap with those observed during the Salesloft Drift incident**. Gainsight did not disclose the initial access mechanism nor how its environment may have been compromised, however, Salesforce stated that the incident was not related to a Salesforce platform vulnerability.

Risk Propagation Through Trusted Integrations

Across both incidents, attackers were able to obtain OAuth tokens used by third-party

applications to connect to customers’ Salesforce environments. Possession of these tokens enabled access to customer data without requiring authentication through traditional login flows or direct interaction with Salesforce user accounts.

Unlike the OAuth Device Flow abuse, these incidents demonstrate how **compromise of a single integration vendor can immediately propagate across multiple customer environments**, resulting in a broader blast radius. They further show that security outcomes in Salesforce environments are increasingly dependent on the integrity of the surrounding integration ecosystem, not solely on configuration or control within individual Salesforce organizations.



AitM Vishing Attacks Targeting SSO Identities

Timeline:

Initial Access Vector:

Impact:

Disclosed in January 2026

AitM phishing combined with vishing

Downstream access to SaaS environments via compromised SSO sessions

In January 2026, publicly reported incidents and [vendor disclosures](#) revealed a wave of identity-focused attacks that occurred during 2025, targeting Single Sign-On (SSO) accounts protected by major identity providers, including Okta and Microsoft Entra ID. These campaigns combined adversary-in-the-middle (AitM) phishing kits with vishing (voice phishing) techniques to bypass MFA controls enforced at the identity provider layer. These attacks followed the same underlying AitM model observed in QR code-based phishing campaigns during 2025. Instead of an initial QR interaction, the attack began with a live phone call, during which the attacker remained on the line with the user throughout the authentication process. In both cases, the attacker positions themselves between

the user and the legitimate identity provider, relaying authentication steps in real time to bypass MFA and capture authenticated sessions. These attacks did not exploit vulnerabilities in identity provider platforms themselves, but instead **abused legitimate authentication flows**.

This activity reflects a growing trend that SaaS platforms increasingly **inherit risk from identity decisions made outside their direct control**. These incidents demonstrate how compromise at the identity provider layer can translate into downstream access to Salesforce environments, even in the absence of Salesforce platform vulnerabilities.



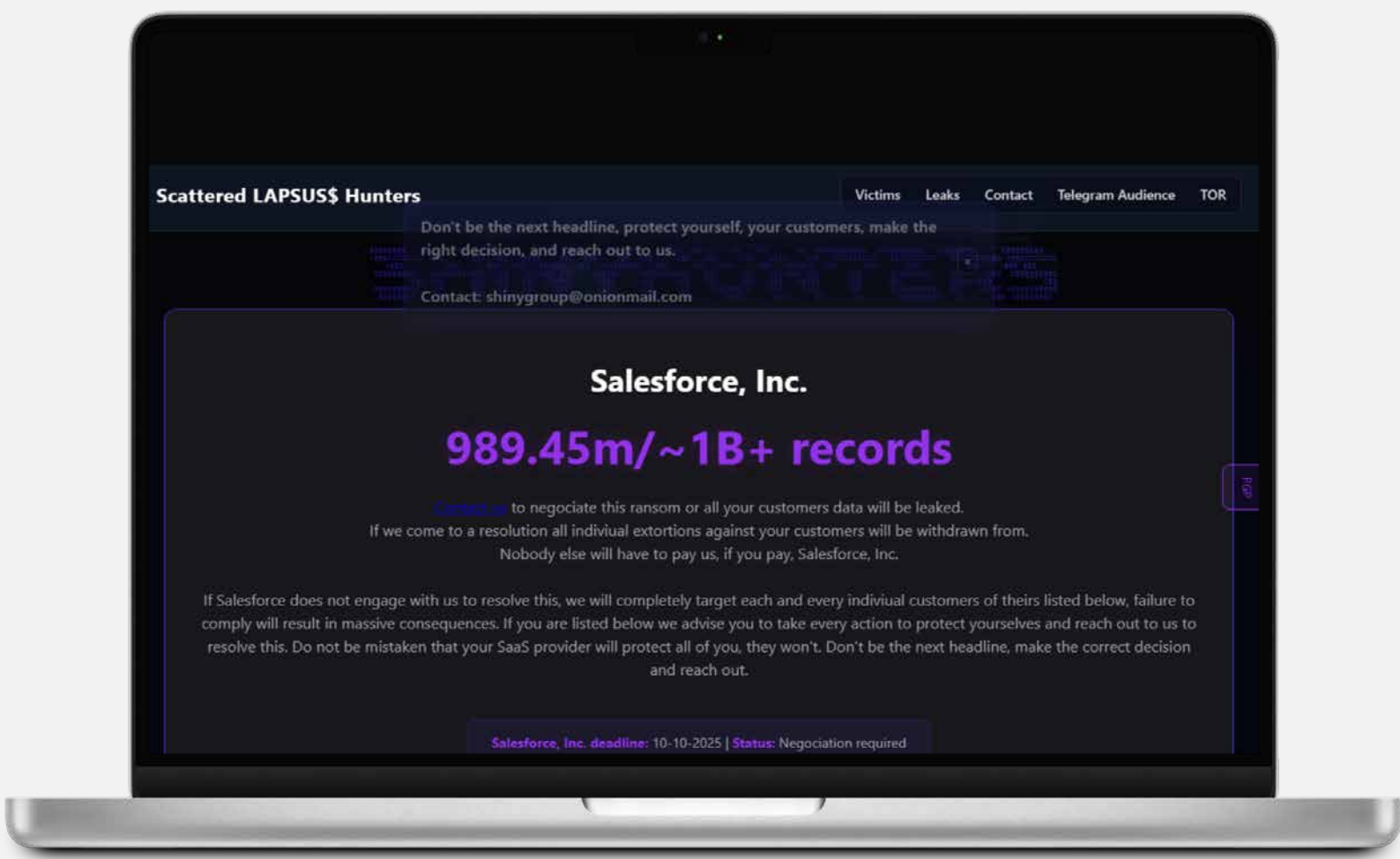
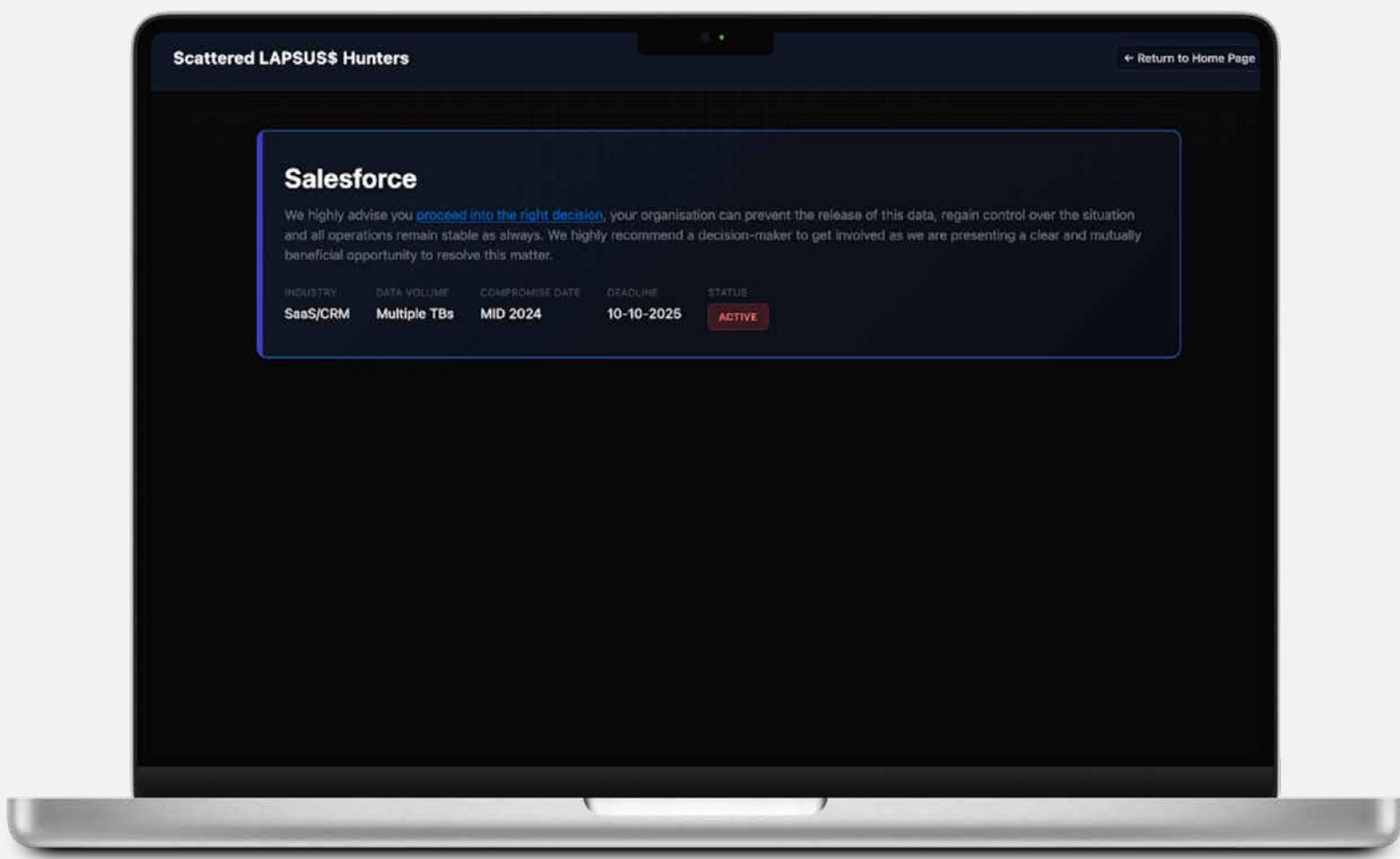
Salesforce as an Extortion Target in Leak-Site Campaigns

In addition to confirmed incidents involving direct access abuse and integration compromise, 2025 also saw Salesforce referenced explicitly in **extortion-focused threat actor activity**. The Scattered Lapsus\$ Hunters cybercriminal alliance publicly listed Salesforce on a dedicated data-leak site, claiming possession of large volumes of sensitive records and threatening public disclosure as part of a broader extortion campaign.

While these claims were not independently verified and the leak site was subsequently seized by authorities, the incident highlights how Salesforce data is perceived by threat actors as a high-

value leverage point. Public naming, branding, and intimidation tactics are increasingly used to amplify pressure on organizations, regardless of whether access was obtained through direct compromise, downstream integrations, or exaggerated claims.

This activity reflects the extortion-driven threat model discussed earlier in this report, where the **perceived sensitivity and regulatory exposure of Salesforce-hosted data is leveraged to increase pressure**, rather than serving as evidence of a compromise of the Salesforce platform itself.



Screenshots from data-leak site illustrate public extortion messaging and threat actor signaling. References to Salesforce data do not indicate a confirmed compromise of the Salesforce platform.

Emerging Salesforce Attack Surfaces: Agents, Automation, and Data Flows

The evolution of Salesforce from a CRM platform into an automation- and agent-driven ecosystem introduces new attack surfaces. These emerging risks are not defined by exploitation of platform vulnerabilities, but by shifts in how trust, authorization, and decision-making are delegated to non-human systems.

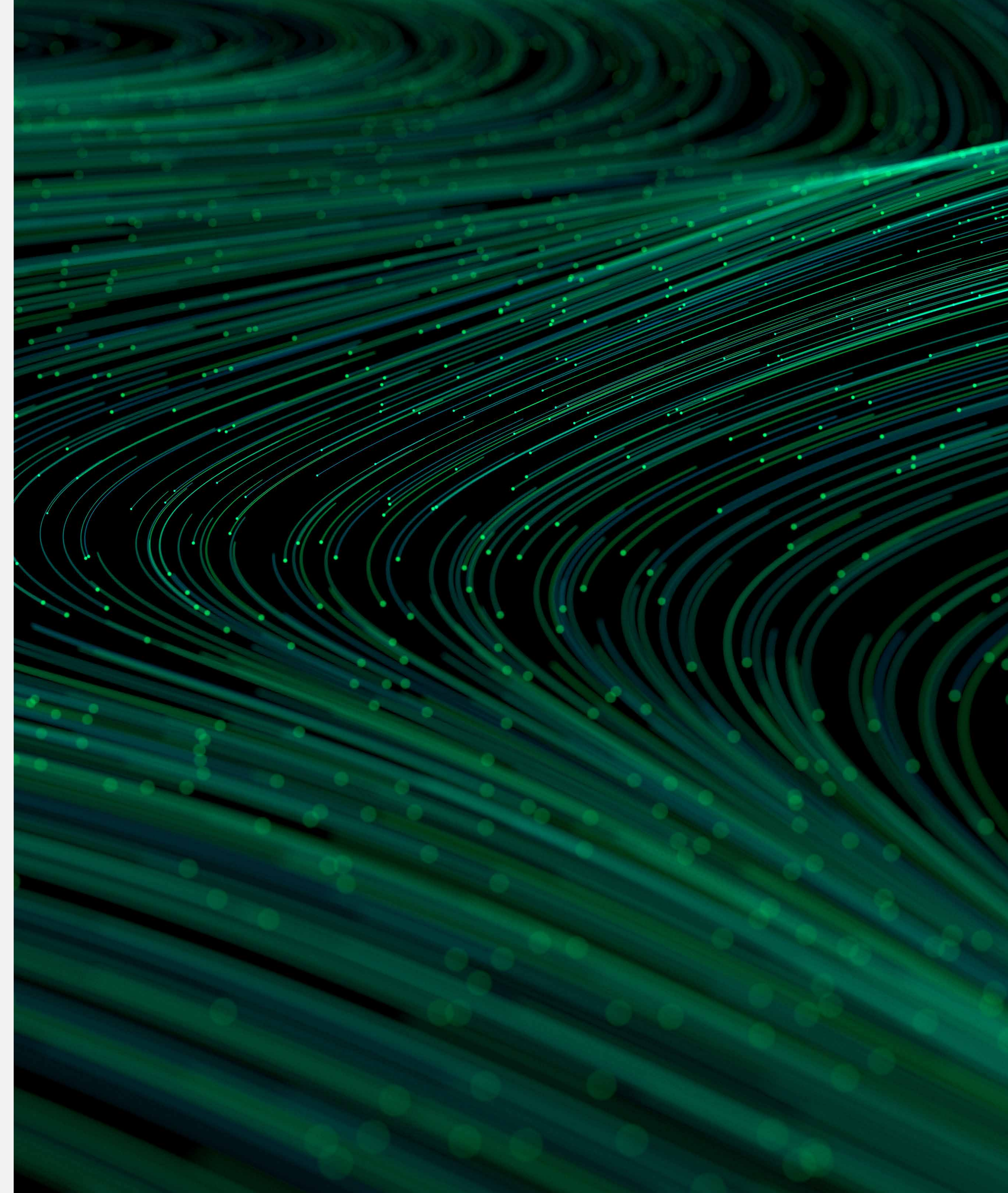


Agents as Autonomous Actors

Agent-based capabilities enable systems to execute actions on behalf of users or roles without continuous human involvement. Unlike traditional automation, which follows predefined workflows, agents may interpret context, make decisions, and act asynchronously.

From a security perspective, this introduces a **shift in identity risk**. Actions performed by agents are still executed under an identity and privilege model, but the **connection between human intent and execution becomes less direct**. Authentication typically occurs at configuration or invocation time rather than at the moment of action, and agents may continue executing actions independently after the initiating user interaction has ended.

As a result, existing weaknesses in identity configuration, such as excessive permissions or inherited trust, can have greater impact when systems act autonomously. Permissions that were acceptable for human-driven actions can become riskier when those same permissions are exercised automatically, repeatedly, and without direct human oversight. This reflects a **shift in trust and responsibility** from direct human control to delegated agent-driven execution.



Automation as an Amplification Layer

Automation within Salesforce environments increasingly connects data sources, workflows, and external systems to streamline business operations. While this improves efficiency, it also changes how errors and misuse propagate once access has been obtained. When combined with agent-based execution, automation further weakens the direct connection between human intent and system behaviour.

In automated environments, a single input, whether legitimate, malformed or malicious, may trigger multiple downstream processes. These actions can include record updates, data synchronization with third-party services, notifications, or additional automated processes. This reduces opportunities for human review and **makes anomalous behaviour more difficult to detect**, particularly when actions occur within expected operational parameters.

From an attack perspective, automation does not necessarily introduce new entry points. Instead, it **magnifies the impact of existing access by enabling actions to occur at scale and speed**. This amplification effect becomes especially relevant when combined with delegated identities or integration-based access. As automation becomes more widespread, security concerns extend beyond access control to how authorized actions can be misused or spread across interconnected systems.



Data as an Input to Automated Decision-Making

As Salesforce environments increasingly rely on centralized data platforms and dynamic data ingestion, **data itself becomes both an asset and a potential vector for indirect influence**. Automated agents and workflows routinely consume data from sources such as customer inputs, support tickets, web forms, and external integrations, using this information to inform decisions, trigger actions, or generate responses.

In such environments, the integrity of data inputs directly affects system behaviour. Manipulated, misleading, or intentionally crafted data may not provide attackers with direct system access, but it can influence how trusted components act within their authorized scope. For example, inaccurate or maliciously introduced content within customer records, support cases, or other data feeds may be processed as legitimate input, shaping automated responses or actions in unintended ways.

With the increasing reliance on automation and agent-driven execution, **data integrity is no longer limited to ensuring data accuracy**, but about how data influences system behaviour. In data-dependent systems, compromised inputs may alter system behaviour, influence automated processes, or result in unintended information disclosure.



Proof-of-Concept: ForcedLeak

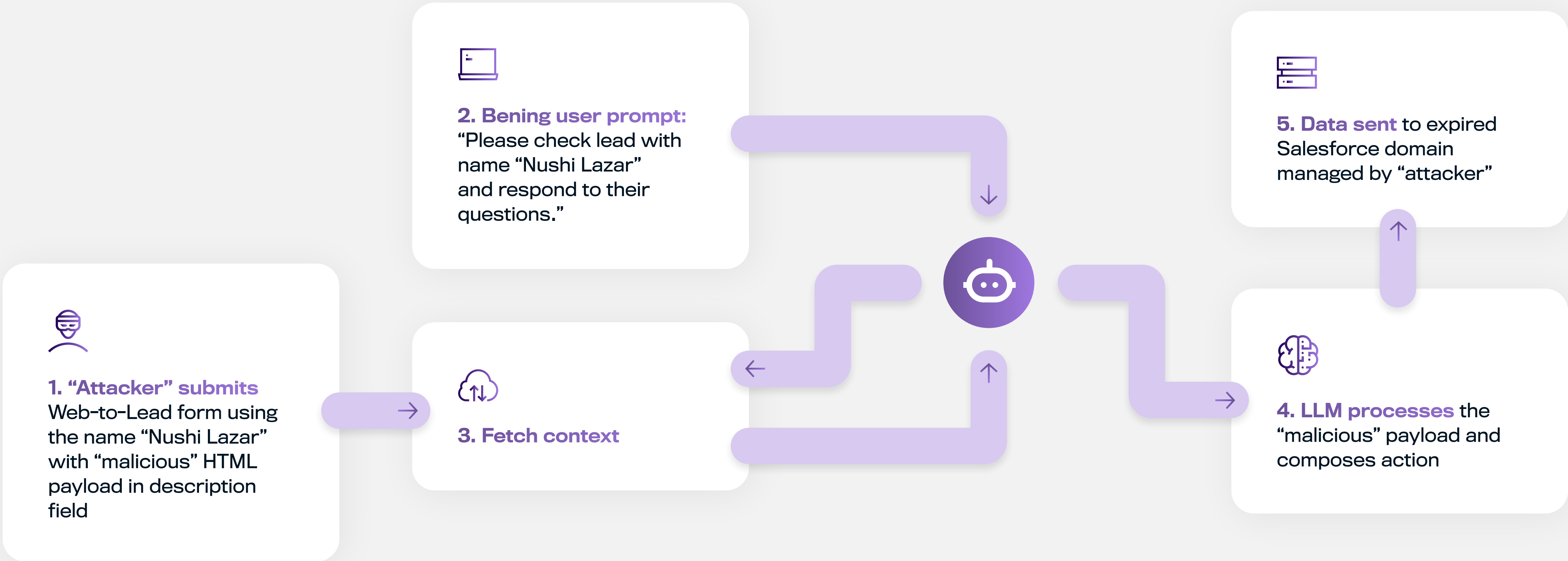
ForcedLeak is a proof-of-concept demonstrated by security researchers at Noma Labs to illustrate how automated agents interacting with dynamic data sources could be influenced into unintentionally disclosing information. In the demonstration, researchers submitted crafted input into a Web-to-Lead form that was later consumed by an automated agent. When the agent processed this data as trusted input, the embedded instructions affected its behaviour and led to unintended information disclosure. This work was conducted responsibly and reported to Salesforce to raise awareness of risks associated with automated decision-making and data trust boundaries.

As more agents rely on dynamic data to operate, risk is no longer limited to who can access a system, but also to what the system is allowed to do with the data it consumes. Data is no longer used solely for storage or viewing; it increasingly shapes

how systems make decisions and take action. As a result, **external inputs can indirectly influence system behaviour** even when access controls remain intact. This makes data governance and oversight critical, particularly in determining how automated systems process, interpret, and act on incoming data.



Simplified ForcedLeak Flow



Salesforce Platform Security-Related Changes

In response to the threats observed, Salesforce implemented several mitigations, such as:

- [Restricting uninstalled connected app usage by requiring explicit permissions](#)
- [Removing OAuth device flow pathway from Data Loader](#)
- Disabling compromised applications from AppExchange (e.g. [Salesloft Drift](#) and [Gainsight](#))
- [Enforcing Trusted URL allowlists for Agentforce and Einstein Generative AI agents](#)
- [Releasing malicious file scanning capability for Salesforce Files](#)

- [Introducing changes to device activation for Single Sign-On \(SSO\) logins](#)
- [Preventing Connected app creation through both API and UI](#)

Collectively, these platform changes **meaningfully reduce risk** associated with identity providers, compromised integrations, delegated access, and file-based threats.

At the same time, detection telemetry from 2025 shows that a large proportion of observed malicious activity relied on URL-based delivery mechanisms, including phishing pages, quishing, and embedded links within otherwise legitimate content. These techniques often fall outside the scope of file-only scanning, reinforcing the importance of **complementary visibility into URLs and content behaviour** as it moves through Salesforce workflows.



Mitigation and Recommendations

The incidents discussed in this report demonstrate that threats targeting Salesforce environments increasingly reflect mature and well-established attack techniques long used in traditional enterprise and endpoint-focused attacks. In this context, effective risk management requires a **layered approach** designed to address evolving usage patterns and a changing threat landscape.



Establish Clear Visibility and Ownership

Organizations should maintain a clear and current understanding of how Salesforce environments are used, integrated, and automated.

Recommended practices include:

- Maintaining an inventory of users, service accounts, connected applications, agents, and automation workflows
- Understanding what data is stored, processed, and shared through Salesforce and its integrations

- Classifying Salesforce assets based on their business impact and potential consequences of misuse or exposure
- Assigning clear ownership for Salesforce security across business, IT, and security teams

Without visibility into identities, integrations, and data flows, it becomes difficult to assess risk or respond effectively when incidents occur.



Manage Integration and Third-Party Risk

Trusted integrations represent a significant source of systemic risk when compromised. Organizations should treat Salesforce integrations as extensions of their own environment.

Recommended practices include:

- Reviewing third-party integrations for necessity, scope, and business justification
- Limiting integration permissions to the minimum required
- Periodically reassessing vendor trust assumptions and integration exposure

Integration risk management should account for the potential impact of vendor compromise across multiple systems and data sets.



Strengthen Identity and Access Governance

Many of the incidents observed in 2025 involved abuse of legitimate access rather than exploitation of technical vulnerabilities. Organizations should therefore focus on how access is granted, delegated, and reviewed over time.

Recommended practices include:

- Enforcing strong authentication and limiting OAuth token lifetimes
- Ensuring upstream identity providers consistently enforce strong authentication, and validating how Salesforce responds when MFA signals are missing, degraded, or unverifiable.
- Applying least-privilege principles to users, integrations, and automated processes
- Regularly reviewing permissions for connected applications, service identities, and delegated access
- Ensuring automation and delegated execution operate within clearly defined and monitored boundaries

Access decisions should reflect not only who requires access, but also how that access can be exercised by automated systems, integrations, and long-lived trust relationships over time.

In support of identity governance, organizations may also benefit from capabilities such as those provided by Cloud Protection for Salesforce, which correlate Salesforce identities with breach data and observed risk signals, complementing existing authentication and access controls.



Monitor for Anomalous Behaviour and Misuse

Detection remains critical, particularly in environments where attackers may blend into normal activity by using legitimate tools and access paths.

Recommended practices include:

- Monitoring for unusual data access patterns, such as large exports or unexpected API activity
- Monitoring for indirect access paths, such as QR code-based authentication flows, delegated authorization, or access initiated outside traditional login interfaces
- Paying attention to changes in connected applications, automation behaviour, or data usage
- Treating anomalous behaviour by trusted identities or systems as a potential indicator of misuse

Access decisions should reflect not only who requires access, but also how that access can be exercised by automated systems, integrations, and long-lived trust relationships over time.

In support of identity governance, organizations may also benefit from capabilities such as those provided by Cloud Protection for Salesforce, which correlate Salesforce identities with breach data and observed risk signals, complementing existing authentication and access controls.



Governance of Automated and Agent-Based Execution

As automation and agent-based execution become more prevalent, organizations should consider how responsibility and trust are delegated to systems.

Recommended practices include:

- Defining clear limits on what automated systems and agents are allowed to do
- Reviewing automation workflows for unintended side effects or excessive scope
- Ensuring that automated actions can be paused, reviewed, or revoked when needed

Organizations should assess whether they can distinguish between actions initiated by human users and those executed by automated systems or agents, particularly during investigations of anomalous behaviour or potential misuse. Automation should be treated as a risk amplifier and governed accordingly.



Data Governance and Content Oversight

Data increasingly influences system behaviour, not just reporting or storage. Organizations should therefore extend governance practices to how data is consumed by automated systems.

Recommended practices include:

- Understanding which data sources feed automation and agents
- Applying oversight to data inputs originating from external or user-generated sources
- Inspecting files, URLs, and content introduced through Salesforce business workflows
- Defining data retention policies aligned with regulatory, legal, and business requirements

Independent content scanning capabilities, such as those provided by Cloud Protection for Salesforce, can enhance native platform protections by applying advanced file and URL analysis before content is consumed by downstream processes or automation.

Data that is no longer required for business or compliance purposes should not be retained indefinitely. Reducing unnecessary data retention lowers exposure, limits the impact of potential misuse, and simplifies incident response. Organizations should periodically review whether retained Salesforce data remains necessary and ensure that retention controls are enforced consistently.



Prepare for Incident Response and Recovery

Organizations should be prepared to respond effectively when security issues arise.

Recommended practices include:

- Maintaining incident response procedures specific to Salesforce environments
- Ensuring the ability to revoke access, disable integrations, and contain exposure quickly
- Learning from incidents and near-misses to improve governance and controls over time

Preparedness reduces both impact and recovery time when incidents occur.



Implement Periodic Security and Configuration Reviews

Salesforce environments support business-critical and often regulated data, yet their security posture can change over time as users, integrations, automation, and permissions evolve. Temporary exceptions, legacy configurations, or relaxed controls introduced during normal operations may persist longer than intended, gradually shifting the environment away from its original security design.

Organizations should establish a recurring review cadence to reassess Salesforce security posture, including:

- Reviewing user, service account, and integration permissions to ensure least-privilege principles still apply
- Revalidating automation and agent workflows to confirm they operate within defined boundaries
- Verifying that previously applied security controls remain enforced as designed
- Conducting role-based simulations to validate how controls perform under realistic misuse or compromise scenarios

- Refreshing targeted security awareness to reflect current attack techniques, such as phishing, QR code-based lures, and impersonation of trusted services

These reviews help counter security drift by ensuring both technical controls and human processes remain aligned with current threat patterns. These should not be one-time exercises, but part of a recurring governance process aligned with risk tolerance and regulatory obligations. Where possible, Salesforce should be reviewed alongside other critical SaaS platforms such as ERP and identity systems to ensure consistent control maturity across the organization's SaaS ecosystem.

Taken together, these recommendations support a recurring operating model for Salesforce security: maintain visibility into trust relationships, apply layered controls, and review changes over time. This helps organizations reduce exposure as Salesforce usage, integrations, and automation evolve.

Conclusion

The Salesforce threat landscape in 2025 reflects a **shift toward identity- and trust-based attacks**, increasingly driven by extortion and data-monetization motives, and executed through legitimate access paths rather than platform vulnerabilities. Adversaries rely on delegated authorization, trusted integrations, and routine workflows to reach sensitive data and create leverage over organizations.

WithSecure Cloud Protection for Salesforce detection telemetry shows that a large share of observed malicious activity is delivered through URLs, embedded links, and QR-code lures that blend into everyday business communications and content exchange. These patterns reinforce the need for visibility into content and interactions flowing through Salesforce environments, alongside file-focused protections.

Looking ahead to 2026 and beyond, the threat activity observed in 2025

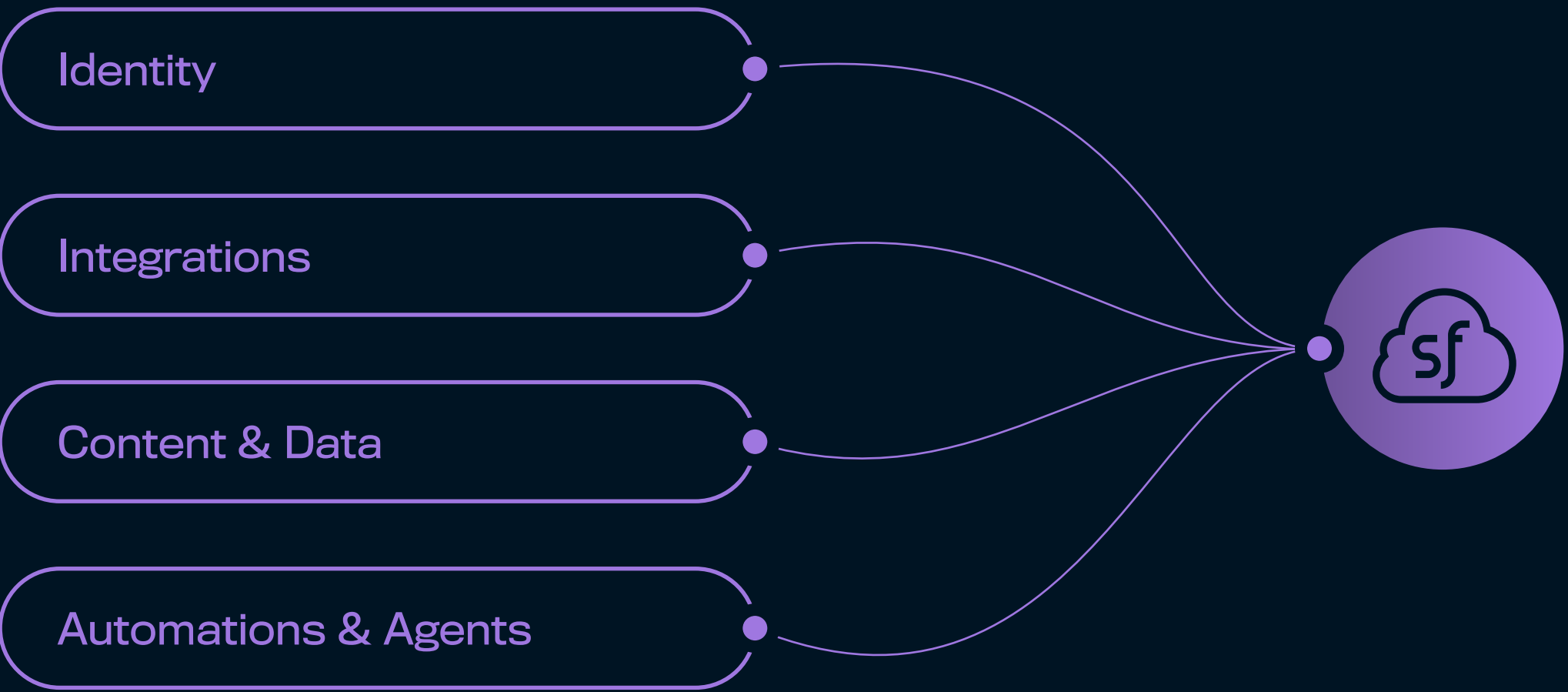
suggests that attacks targeting Salesforce environments have moved beyond exploratory or opportunistic stages and reached **mainstream adoption among financially motivated threat actors**. In parallel, recent identity provider–focused AitM campaigns and Salesforce’s subsequent SSO-related changes highlight how downstream SaaS risk increasingly depends on the strength and assurance of upstream identity decisions.

Continued growth in automation, agent-driven execution, and AI-assisted workflows will expand the number of non-human processes and long-lived trust relationships operating within Salesforce environments. As Salesforce environments evolve into complex, multi-vendor ecosystems that combine identity providers, integrations, automation, and logic-driven workflows, security **risk increasingly emerges from how trusted components interact**, rather than from isolated vulnerabilities or

misconfigurations. As a result, effective defense will depend on maintaining visibility into how trust is established, delegated, and exercised over time across identities, integrations, content, and automation.

Organizations that treat Salesforce security as an **ongoing program, supported by layered detection, clear ownership, and**

periodic control reviews, will be better positioned to manage evolving risk. Security controls that extend visibility into trusted workflows, rather than focusing solely on isolated events or traditional boundaries, will be critical to sustaining resilience as both the platform and threat landscape continue to evolve.



Expanding trust surfaces in Salesforce environments



#1 Cyber Security Solution for Modern Salesforce Threats

cloudprotection.com